

**TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN**

NGUYỄN CÔNG LẬP – VÕ MINH TUẤN

**TÌM HIỂU VỀ HỆ THỐNG CTEM
VÀ XÂY DỰNG MỘT HỆ THỐNG MINH HỌA**

**THỰC TẬP DỰ ÁN TỐT NGHIỆP CỬ NHÂN CNTT
CHƯƠNG TRÌNH CHẤT LƯỢNG CAO**

Tp. Hồ Chí Minh, tháng 08/2025

**TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN**

**NGUYỄN CÔNG LẬP – 21127339
VÕ MINH TUẤN - 21127472**

**TÌM HIỂU VỀ HỆ THỐNG CTEM
VÀ XÂY DỰNG MỘT HỆ THỐNG MINH HỌA**

**THỰC TẬP DỰ ÁN TỐT NGHIỆP CỬ NHÂN CNTT
CHƯƠNG TRÌNH CHẤT LƯỢNG CAO**

GIÁO VIÊN HƯỚNG DẪN

ThS. Lê Giang Thanh

Tp. Hồ Chí Minh, tháng 08/2025

Lời cảm ơn

Chúng em xin chân thành cảm ơn khoa Công nghệ thông tin cũng như trường Đại học Khoa học tự nhiên đã cho chúng em cơ hội học hỏi trong gần bốn năm học qua. Trong khoảng thời gian ấy chúng em đã tiếp thu được nhiều kiến thức nền tảng và những kỹ năng hữu ích để có thể áp dụng được trong công việc và cuộc sống sau này. Đồng thời chúng em cũng muốn bày tỏ lòng biết ơn sâu sắc đến thầy Lê Giang Thanh đã giúp đỡ cả chặng đường thực hiện thực tập đồ án này. Đây chính là bước đệm cuối cùng mà thầy Lê Giang Thanh cũng như các thầy cô khác tiếp sức cho chúng em trước khi bước vào thị trường lao động đầy khắc nghiệt.

Do chưa có nhiều kinh nghiệm thực tiễn, nhóm chúng em vẫn còn nhiều sai sót trong việc triển khai đồ án này, mong thầy cô góp ý và hướng dẫn.

ĐỀ CƯƠNG THỰC TẬP DỰ ÁN TỐT NGHIỆP**TÌM HIỂU VỀ HỆ THỐNG CTEM
VÀ XÂY DỰNG MỘT HỆ THỐNG MINH HỌA****1. THÔNG TIN CHUNG****1.1. Tên đề tài:**

Tìm hiểu về hệ thống CTEM và xây dựng một hệ thống minh họa

1.2. Giảng viên hướng dẫn: Lê Giang Thanh (Khoa Công Nghệ Thông Tin)**1.3. Sinh viên thực hiện:**

1. Nguyễn Công Lập – MSSV: 21127339
2. Võ Minh Tuấn – MSSV: 21127472

1.4. Thời gian thực hiện: Từ 01/2025 đến 07/2025**1.5. Loại đề tài:** Ứng dụng**2. NỘI DUNG ĐỀ TÀI**

2.1. Giới thiệu về đề tài

Khi các doanh nghiệp/tổ chức chuyển đổi kỹ thuật số, đồng nghĩa với nó, các mối đe dọa trên không gian mạng cũng phát triển nhanh hơn. Chúng ta sẽ đồng thời đối mặt vấn đề rằng các mối đe dọa sẽ ngày càng trở nên tinh vi hơn; và làm sao để các giải pháp quản lý lỗ hổng có thể phản ứng nhanh chóng và hiệu quả hơn.

Hệ thống bảo mật truyền thống chủ yếu dựa vào các phương pháp phản ứng, tức là chỉ phát hiện và xử lý sự cố sau khi chúng đã xảy ra, khiến việc quản lý lỗ hổng bảo mật không mang tính liên tục. Các tổ chức thường chỉ đánh giá bảo mật định kỳ, khiến nhiều rủi ro tồn đọng trong thời gian dài mà không được xử lý kịp thời. Điều này khiến tổ chức dễ bị tấn công và gây ra những thiệt hại nghiêm trọng về dữ liệu, tài chính và uy tín. Do đó các tổ chức cần phải xây dựng các hệ thống bảo mật có tính liên tục, trong đó thực hiện các hành động có thể đo lường được để phát hiện và ngăn chặn các mối đe dọa và lỗ hổng tiềm ẩn một cách nhất quán. Việc xây dựng một hệ thống bảo mật có tính liên tục giúp các tổ chức chủ động phát hiện và giảm thiểu rủi ro an ninh mạng trước khi chúng bị khai thác. Thay vì chỉ phản ứng khi sự cố xảy ra, hệ thống này cho phép giám sát, đánh giá và tối ưu hóa bảo mật một cách liên tục, giúp giảm thiểu tổn thất về dữ liệu, tài chính và uy tín.

Continuous Threat Exposure Management (CTEM), ra đời như một giải pháp tiếp cận chủ động hơn, giúp tổ chức có thể liên tục đánh giá mức độ phơi nhiễm trước các mối đe dọa, từ đó ưu tiên và triển khai các biện pháp giảm thiểu rủi ro trước khi bị khai thác. Theo Gartner, đến năm 2026, các tổ chức ưu tiên "đầu tư bảo mật của họ dựa trên Chương trình Quản lý Liên tục Mức Độ Tiềm Ẩn Mối Đe Dọa CTEM sẽ có khả năng bị

vi phạm ít hơn 3 lần"[1]. Điều này chứng tỏ việc tìm hiểu và xây dựng một hệ thống CTEM là điều quan trọng và cần thiết cho mỗi tổ chức hoặc doanh nghiệp.

2.2. Mục tiêu đề tài

Như đã nói ở phía trên, quản lý lỗ hổng truyền thống thường mang tính phản ứng: tổ chức chỉ khắc phục các lỗ hổng sau khi phát hiện mối đe dọa và đánh giá rủi ro bảo mật theo chu kỳ định kỳ. Tuy nhiên, với bối cảnh tấn công không ngừng thay đổi hiện nay, cách tiếp cận này không còn hiệu quả.

Mục tiêu bao quát của CTEM là ưu tiên các chiến lược giảm thiểu/xử lý rủi ro tiềm ẩn và liên tục tinh chỉnh kế hoạch cải thiện tư thế bảo mật của bạn để ưu tiên các chiến lược giảm thiểu rủi ro tiềm ẩn và liên tục tinh chỉnh kế hoạch cải thiện tư thế bảo mật của bạn bằng cách chuyển từ đánh giá lỗ hổng tại thời điểm sang chương trình xác thực và khắc phục tư thế bảo mật có thể lặp lại. Bằng cách thường xuyên phơi bày tài sản của tổ chức trước các cuộc tấn công mô phỏng, CTEM cho phép họ xác định và khắc phục các lỗ hổng và kiểm soát các lỗ hổng trước khi các tác nhân độc hại có thể khai thác chúng.[2]

Với tốc độ chuyển đổi số hiện tại và sự gia tăng các mối đe dọa mạng, tìm hiểu và xây dựng một hệ thống CTEM mang đến một phương pháp tiếp cận có hệ thống, thực tế và linh hoạt hơn, giúp tổ chức ưu tiên và cải tiến khả năng phòng vệ theo thời gian thực.

2.3. Phạm vi của đề tài

Nội dung nghiên cứu chính của đề tài sẽ tìm hiểu về khái niệm, vai trò, các giai đoạn

hoạt động của một hệ thống CTEM và các thách thức khi triển khai. Đồng thời đề tài cũng xây dựng một hệ thống CTEM minh họa với các chức năng cơ bản tương ứng với từng giai đoạn hoạt động như đã được tìm hiểu.

2.4. Cách tiếp cận dự kiến

Đề tài này sẽ nghiên cứu, tìm hiểu các thông tin có liên quan đến hệ thống CTEM từ các trang thông tin chính thống. Thông qua đó, chúng em sẽ xây dựng một hệ thống CTEM minh họa với các chức năng cơ bản từ việc tích hợp các mã nguồn mở có sẵn cho các chức năng tương ứng với từng giai đoạn của một hệ thống CTEM.

2.5. Kết quả dự kiến

Sau khi đề tài được hoàn thiện, chúng ta sẽ đạt được một số các kết quả sau:

- Hiểu được các khái niệm, các bước hoạt động liên quan đến một hệ thống CTEM
- Nhận thức được vai trò của hệ thống CTEM trong thực tế và các thách thức để phát triển trong tương lai
- Xây dựng được một hệ thống CTEM với các chức năng:
 - Xác định phạm vi: xác định các host/tài sản trên network
 - Khám phá: xác định các lỗ hổng, lỗi cấu hình của từng loại tài sản và các biện pháp bảo mật tương ứng
 - Ưu tiên: cân nhắc mức độ đe dọa mà các rủi ro có thể gây ra
 - Xác thực: mô phỏng lại các hình thức tấn công qua đó đánh giá khả năng xảy ra và thiệt hại mà nó mang lại

2.6. Kế hoạch thực hiện

Thời gian bắt đầu	Thời gian kết thúc (dự kiến)	Nội dung thực hiện	Thành viên
1/2025	2/2025	Tìm hiểu khái niệm, vai trò, các giai đoạn hoạt động của một hệ thống CTEM và các thách thức khi triển khai.	Võ Minh Tuấn, Nguyễn Công Lập
1/2025	2/2025	Tham khảo giao diện và chức năng các hệ thống CTEM có sẵn	Võ Minh Tuấn, Nguyễn Công Lập
2/2025	3/2025	Tìm kiếm các mã nguồn mở có sẵn phù hợp với các chức năng cần thực hiện	Võ Minh Tuấn, Nguyễn Công Lập
2/2025	3/2025	Xác định các công nghệ, môi trường phù hợp cho việc xây dựng hệ thống	Võ Minh Tuấn, Nguyễn Công Lập
4/2025	6/2025	Xây dựng giao diện UI/UX	Võ Minh Tuấn
4/2025	6/2025	Xây dựng cơ sở dữ liệu cho việc lưu trữ các thông tin về rủi ro	Nguyễn Công Lập
4/2025	5/2025	Hoàn thiện chức năng ở giai đoạn <i>Xác định phạm vi</i>	Võ Minh Tuấn
4/2025	5/2025	Hoàn thiện chức năng ở giai đoạn <i>Khám phá</i>	Nguyễn Công Lập
5/2025	6/2025	Hoàn thiện chức năng ở giai đoạn <i>Ưu tiên</i>	Võ Minh Tuấn

5/2025	6/2025	Hoàn thiện chức năng ở giai đoạn <i>Xác thực</i>	Nguyễn Công Lập
6/2025	7/2025	Hoàn thiện và kiểm thử toàn bộ dự án	Võ Minh Tuấn, Nguyễn Công Lập

Tài liệu

- [1] “Giải mã khái niệm CTEM trong ngành An toàn thông tin”,
<https://vnccs.vn/vi/tin-tuc/detail-giai-ma-khai-niem-ctem-trong-nganh-an-toan-thong-tin-392>.
- [2] “What is Continuous Threat Exposure Management?”,
<https://www.kroll.com/en/insights/publications/cyber/what-is-continuous-threat-exposure-management>.

XÁC NHẬN

TP. Hồ Chí Minh, ngày 2 tháng 4 năm 2025

CỦA NGƯỜI HƯỚNG DẪN

NHÓM SINH VIÊN THỰC HIỆN

(Ký và ghi rõ Họ tên)

(Ký và ghi rõ họ tên)

Mục lục

Lời cảm ơn	i
Mục lục	ii
Danh sách các hình.....	v
Danh sách các bảng.....	viii
Tóm tắt	ix
Chương 1 Giới thiệu hệ thống CTEM.....	1
1.1. Khái niệm.....	1
1.2. 5 giai đoạn của một hệ thống CTEM	2
1.2.1. Giai đoạn Scoping – Xác định phạm vi.....	3
1.2.2. Giai đoạn Discovery – Khám phá	3
1.2.3. Giai đoạn Prioritization – Xác định mức độ ưu tiên	4
1.2.4. Giai đoạn Validation – Đánh giá.....	4
1.2.5. Giai đoạn Mobilization – Triển khai	5
Tổng kết.....	5
1.3. Tính ưu việt của CTEM	8
1.3.1. Tính ưu việt	8
1.3.2. So sánh với các phương pháp quản lý lỗi hỏng cụ thể.....	9
1.4. Lợi ích của việc sử dụng hệ thống CTEM	11
1.5. Những thách thức khi triển khai hệ thống CTEM	12
Chương 2 Giới thiệu một số nền tảng CTEM	14
2.1. Nanitor	14

2.1.1. Giới thiệu	14
2.1.2. Các giải pháp chính	18
2.2. Tenable.....	19
2.2.1. Giới thiệu.....	19
2.2.2. Các giải pháp chính	22
2.3. XM Cyber	22
2.3.1. Giới thiệu.....	22
2.3.2. Các giải pháp chính	25
So sánh	26
Chương 3 Các công cụ hỗ trợ.....	27
3.1. Nmap	27
3.2. OpenVAS	28
3.3. Metasploit Framework.....	29
Tổng kết	30
Chương 4 Xây dựng hệ thống	31
4.1. Các công nghệ được sử dụng	31
4.2. Kiến trúc hệ thống	32
4.2.1. Tổng quan.....	32
4.2.2. Kiến trúc back-end	33
4.2.3. Mô hình ERD cho database.....	34
4.3. Luồng hoạt động	35
4.3.1. Luồng hoạt động khởi động hệ thống	36
4.3.2. Luồng hoạt động của các tính năng.....	40
Chương 5 Kết quả thực nghiệm.....	43
5.1. Môi trường kiểm thử - Metasploitable 3	43
5.2. Kịch bản kiểm thử	43

5.3. Kết quả.....	44
Chương 6 Tổng kết.....	49
6.1. Kết quả đạt được.....	49
6.2. Hướng phát triển	50
6.3. Kết luận.....	50
Tài liệu tham khảo	51
Phụ lục A	54
Phụ lục B	57

Danh sách các hình

Hình 1-1 Các giai đoạn của một hệ thống CTEM.....	2
Hình 2-1 Logo Nanitor.....	14
Hình 2-2 Nanitor Diamond Vision.....	15
Hình 2-3 Overview dashboard	16
Hình 2-4 Nanitor – Assets Inventory	17
Hình 2-5 Nanitor – Issues List	17
Hình 2-6 Nanitor – Prioritization	18
Hình 2-7 Logo Tenable	19
Hình 2-8 Tenable Nessus – Overview dashboard.....	20
Hình 2-9 Tenable Nessus – Show scan result in dashboard view.....	20
Hình 2-10 Tenable Nessus – List of a single host's scan results.....	21
Hình 2-11 Tenable Nessus – Details of a single host's plugin scan result.....	21
Hình 2-12 Logo XM Cyber.....	22
Hình 2-13 XM Cyber Choke point	23
Hình 2-14 XM Cyber – Overview dashboard.....	24
Hình 2-15 XM Cyber – Scenario Hubs.....	24

Hình 2-16 XM Cyber - Report	25
Hình 3-1 Logo Nmap	27
Hình 3-2 Zenmap – GUI của Nmap	28
Hình 3-3 Logo openVAS	28
Hình 3-4 GUI của OpenVAS Greenbone	29
Hình 4-1 Kiến trúc hệ thống.....	32
Hình 4-2 Mô hình ERD cho database	34
Hình 4-3 Luồng hoạt động chính trong hệ thống.....	35
Hình 4-4 Server Initialization Flow	36
Hình 4-5 FastAPI Application Lifecycle – Startup phase.....	37
Hình 4-6 FastAPI Application Lifecycle – Runtime phase	38
Hình 4-7 FastAPI Application Lifecycle – Shutdown phase.....	39
Hình 4-8 Asset Discovery Flow	40
Hình 4-9 Vulnerability Assessment Flow	41
Hình 4-10 Dashboard Data Flow	42
Hình 5-1 Kịch bản kiểm thử.....	44
Hình 5-2 Nmap Scan.....	44
Hình 5-3 OpenVAS Scan	45

Hình 5-4 Metasploit Framework validate	45
Hình 5-5 LLM solution	46
Hình 5-6 Dashboard Overview	46
Hình 5-7 Threat Intelligence	47
Hình 5-8 Asset Management.....	47
Hình 5-9 Security Analytics.....	48

Danh sách các bảng

Bảng 1-1 Tổng kết các chức năng chính cho từng giai đoạn	7
Bảng 1-2 So sánh CTEM với các giải pháp truyền thống.....	8
Bảng 2-1 Các giải pháp chính của Nanitor	18
Bảng 2-2 Các giải pháp chính của Tenable.....	22
Bảng 2-3 Các giải pháp chính của XM Cyber	25
Bảng 2-4 Bảng so sánh các nền tảng CTEM	26
Bảng 3-1 Bảng tổng kết các công cụ hỗ trợ	30
Bảng 4-1 Bảng tổng kết các công nghệ sử dụng	31
Bảng 4-2 Bảng mô tả kiến trúc back-end.....	34

Tóm tắt

Ngày nay, các mối đe dọa trên không gian mạng phát triển càng nhanh trong khi các hệ thống bảo mật truyền thống chủ yếu dựa vào các phương pháp phản ứng, tức là chỉ phát hiện và xử lý sự cố sau khi chúng đã xảy ra, khiến việc quản lý lỗ hổng bảo mật không mang tính liên tục. CTEM là một phương pháp quản lý lỗ hổng bảo mật với nhiều tính ưu việt, giúp tổ chức có thể liên tục đánh giá mức độ phơi nhiễm trước các mối đe dọa, từ đó ưu tiên và triển khai các biện pháp giảm thiểu rủi ro. Đây là một hướng đi mới trong việc quản lý lỗ hổng bảo mật. Đề tài này đưa ra khái niệm cùng các giai đoạn của một hệ thống CTEM, tính ưu việt so với các phương pháp cũ, đồng thời xây dựng một hệ thống minh họa cho một mạng máy tính gồm các máy ảo. Nhóm đã nghiên cứu thông tin từ các trang chính thống và từ đó sử dụng các công cụ mã nguồn mở (Nmap, OpenVAS, Metasploit) để xây dựng một hệ thống minh họa cho từng giai đoạn của một hệ thống CTEM, và xây dựng một network gồm các máy ảo trên VMWare để kiểm tra. Nhóm đã thành công xây dựng được một hệ thống minh họa để quản lý cho một mạng máy tính gồm 2 máy ảo. Đề tài đã tạo điều kiện trong việc xây dựng một hệ thống CTEM trong thực tế cho doanh nghiệp, nâng cao khả năng giảm thiểu rủi ro.

Chương 1 Giới thiệu hệ thống CTEM

1.1. Khái niệm

Năm 2022, Gartner đã đưa ra thuật ngữ và khái niệm về quản lý tiếp xúc mối đe dọa liên tục CTEM (Continuous Threat Exposure Management). Đây là một chương trình, hay khuôn khổ, chủ động và liên tục gồm năm giai đoạn, giúp giảm thiểu nguy cơ bị tấn công mạng. CTEM giúp các tổ chức xác định các lỗ hổng và nguy cơ bị tấn công, đối chiếu chúng với các đường dẫn tấn công tiềm ẩn, ưu tiên chúng dựa trên mức độ rủi ro đối với các tài sản quan trọng và theo dõi tiến độ triển khai các hoạt động khắc phục.[7]

Quản lý lỗ hổng truyền thống thường mang tính phản ứng: tổ chức chỉ khắc phục các lỗ hổng sau khi phát hiện mối đe dọa và đánh giá rủi ro bảo mật theo chu kỳ định kỳ. Tuy nhiên, với bối cảnh tấn công không ngừng thay đổi hiện nay, cách tiếp cận này không còn hiệu quả.[1] So với các phương pháp truyền thống, CTEM tập trung vào việc xác định các mối đe dọa trước khi chúng có thể bị khai thác bằng cách liên tục giám sát và đánh giá các lỗ hổng [10]. Điều này cho phép các tổ chức ứng phó với rủi ro bảo mật nhanh hơn các phương pháp trước đây. Do đó, CTEM là một phương pháp chủ động và liên tục [10].

1.2. 5 giai đoạn của một hệ thống CTEM



Hình 1-1 Các giai đoạn của một hệ thống CTEM

Một hệ thống CTEM sẽ có 5 giai đoạn, bao gồm:

- Scoping: Xác định phạm vi
- Discovery: Khám phá
- Prioritization – Xác định mức độ ưu tiên
- Validation – Đánh giá
- Mobilization – Triển khai

1.2.1. Giai đoạn Scoping – Xác định phạm vi

Bước đầu tiên của quy trình CTEM là xác định phạm vi bề mặt tấn công của tổ chức. Điều này có nghĩa là trước khi tìm kiếm các lỗ hổng hoặc mối đe dọa, tổ chức cần xác định những lĩnh vực, tài sản hoặc quy trình nào quan trọng nhất cần bảo vệ dựa trên giá trị của chúng đối với hoạt động kinh doanh. Hai lĩnh vực chính để xác định phạm vi cho các tổ chức mới tham gia vào quy trình này là:

- Bề mặt tấn công bên ngoài
- Tình hình bảo mật SaaS

Giai đoạn xác định phạm vi rất quan trọng để đặt nền tảng cho các giai đoạn tiếp theo bằng cách xác định nội dung cần đánh giá, lý do đánh giá và cách thức thực hiện. Nó giúp đảm bảo các nỗ lực quản lý phơi nhiễm được tập trung, có mục tiêu và phù hợp với các mục tiêu và ưu tiên của tổ chức[2].

1.2.2. Giai đoạn Discovery – Khám phá

Giai đoạn khám phá của CTEM bao gồm việc chủ động tìm kiếm và xác định các lỗ hổng tiềm ẩn trong hệ thống và tài sản của tổ chức. Việc phát hiện không chỉ đơn thuần là tìm ra lỗ hổng trong phần mềm hoặc phần cứng, mà còn bao gồm cả việc xác định các cấu hình sai trong tài sản và biện pháp kiểm soát an ninh.

Giai đoạn này tập trung vào việc xác định chi tiết tất cả các tài sản và lỗ hổng liên quan đến phạm vi đã xác định. Phạm vi này không chỉ bao gồm các tài sản hiển thị và dễ thấy nhất mà còn bao gồm tất cả các tài sản ẩn. Chúng có thể bao gồm [10]:

- Các kho lưu trữ mã trực tuyến như GitHub hoặc Bitbucket, nơi kẻ tấn công có thể xác định lỗ hổng mã

- Tài khoản mạng xã hội của công ty mà kẻ tấn công có thể sử dụng các kỹ thuật kỹ thuật xã hội để vạch trần
- Các lỗ hổng của phần mềm và ứng dụng của bên thứ ba
- Nền tảng đám mây

Ngoài ra, ngoài việc phát hiện tài sản kỹ thuật số và vật lý, các tổ chức phải thực hiện đánh giá chi tiết về các lỗ hổng và cấu hình sai của các tài sản này để đánh giá hồ sơ rủi ro của chúng.

1.2.3. Giai đoạn Prioritization – Xác định mức độ ưu tiên

Sau khi xác định được các lỗ hổng, hệ thống CTEM sẽ xếp hạng chúng dựa trên tác động tiềm tàng và khả năng bị khai thác. Quy trình ưu tiên này giúp tổ chức tập trung nguồn lực vào các mối đe dọa quan trọng nhất [2] vì không phải tất cả mọi thứ đều cần được đưa vào kế hoạch huy động và xác nhận ngay lập tức.

Một trong những chỉ số phổ biến được sử dụng là CVSS (Common Vulnerability Scoring System) – hệ thống chấm điểm mức độ nghiêm trọng của lỗ hổng từ 0 đến 10, trong đó các lỗ hổng có điểm từ 7.0 trở lên thường được xem là nghiêm trọng hoặc nghiêm trọng cao. Ngoài ra, CVE (Common Vulnerabilities and Exposures) cung cấp mã định danh duy nhất cho từng lỗ hổng đã được công khai, giúp dễ dàng tra cứu và đối chiếu với dữ liệu thực tế.

1.2.4. Giai đoạn Validation – Đánh giá

Trong giai đoạn này, hệ thống sẽ triển khai các cuộc tấn công mô phỏng vào các điểm yếu đã được xác định trước đó để đánh giá hiệu quả của các biện pháp phòng thủ hiện có, đồng thời xác minh tính đầy đủ của các biện pháp ứng phó và khắc phục ngay lập tức[2].

Giai đoạn xác thực rất quan trọng vì bằng cách thường xuyên kiểm tra và xác nhận rằng các biện pháp kiểm soát và quy trình có hiệu quả, các tổ chức có thể chắc chắn rằng hệ thống của họ an toàn nhất có thể trước các mối đe dọa có thể xảy ra.[4]

1.2.5. Giai đoạn Mobilization – Triển khai

Mục tiêu của giai đoạn này là đảm bảo các nhóm khác nhau trong tổ chức có thể hành động và chuyển đổi các phát hiện thành những cải tiến bảo mật khả thi một cách hiệu quả. Trọng tâm là đạt được sự chấp thuận và triển khai các biện pháp giảm thiểu để giải quyết các lỗ hổng và điểm yếu đã được xác định. Điều này giúp đảm bảo các quy trình an ninh được thông suốt, không có rào cản và các nỗ lực an ninh với các quy trình tự động hóa và mục tiêu kinh doanh được tích hợp với nhau

Tổng kết

Dưới đây là bảng tổng kết các chức năng cần có ở từng giai đoạn của một hệ thống CTEM:

Giai đoạn	Chức năng	Công cụ hỗ trợ
Scoping	- Tự động phát hiện tất cả các tài sản của tổ chức và phân loại chúng dựa trên bối cảnh kinh doanh. - Xác định mức độ quan trọng của từng tài sản. - Hiển thị mối quan hệ giữa các tài sản với nhau.	CyCognito – Tự động phát hiện tài sản và đánh giá rủi ro bên ngoài Palo Alto Networks Xpanse – Lập bản đồ bề mặt tấn công từ bên ngoài Microsoft Defender EASM – Khám phá tài sản kỹ thuật số chưa được kiểm soát Shodan / Censys – Quét và tìm tài sản công khai trên Internet

Discovery	• Xác định các dịch vụ, tài sản từ bên thứ ba như các ứng dụng web hoặc tài sản đám mây và các thành phần chính của chúng • Phát hiện rủi ro có trong tất cả các tài sản và cung cấp khả năng phát hiện rủi ro định kỳ	Tenable.asm / Tenable.io – Phát hiện tài sản & đánh giá rủi ro toàn diện (cloud, web apps, services) Qualys Global AssetView – Tự động phát hiện, phân loại tài sản và kiểm tra tình trạng bảo mật Rapid7 InsightVM – Phát hiện liên tục tài sản mạng và rủi ro trong môi trường động CrowdStrike Falcon Discover – Xác định ứng dụng, người dùng và dịch vụ trên endpoints & cloud Microsoft Defender for Cloud – Phát hiện và đánh giá rủi ro với tài sản đám mây Nessus – Quét và phát hiện các lỗ hổng trên các hệ thống nội bộ hoặc cloud
Prioritization	Cung cấp khả năng ưu tiên dựa trên rủi ro thông qua	Kenna Security (Cisco Vulnerability Management) – Xếp hạng lỗ hổng dựa trên rủi ro theo ngữ cảnh doanh nghiệp, threat intelligence & khả năng khai thác RiskSense (Ivanti) – Phân tích rủi ro và gợi ý khắc phục ưu tiên dựa trên điểm CVSS, khả năng khai thác thực tế
Validation	• Xác thực phát hiện rủi ro bằng cách sử dụng các công cụ kiểm tra bảo mật chủ động • Thu thập bằng chứng cho tất cả kết quả thử nghiệm và cung cấp bằng chứng thông qua	OWASP ZAP – Công cụ DAST mã nguồn mở để thử nghiệm ứng dụng web Nessus / Tenable.io – Kiểm tra bảo mật chủ động, phát hiện cấu hình sai và xác minh lỗi Metasploit Framework – Thử nghiệm khai thác lỗ hổng (exploit validation)

	bảng điều khiển và API • Xác thực các nỗ lực khắc phục thông qua thử nghiệm bảo mật tích cực	AttackIQ / SafeBreach / Cymulate – Mô phỏng mối đe dọa (Breach and Attack Simulation - BAS) để kiểm chứng các biện pháp khắc phục Pentest tools – Bộ công cụ kiểm thử bảo mật tự động hóa
Mobilization	• Cung cấp kế hoạch khắc phục có thể theo dõi cho từng tổ chức và từng môi trường trong tổ chức • Cung cấp hướng dẫn kiểm tra để đơn giản hóa việc xác nhận • Cung cấp số liệu để thể hiện sự cải thiện về tình trạng rủi ro theo thời gian • Cung cấp số liệu thể hiện xu hướng khắc phục theo thời gian • Bao gồm tự động hóa quy trình làm việc và tích hợp giao tiếp thông qua API để cung cấp thông tin tiếp xúc	Jira / ServiceNow / Asana – Quản lý kế hoạch khắc phục, phân công nhiệm vụ, theo dõi tiến độ Confluence / Notion / GitBook – Lưu trữ và chia sẻ hướng dẫn kiểm tra/xác minh Mitre ATT&CK Navigator – Hướng dẫn áp dụng chiến thuật/phương pháp phòng thủ SecurityScorecard / RiskRecon – Giám sát và cung cấp dữ liệu rủi ro theo môi trường GRC Tools (Governance, Risk, Compliance) như Archer, MetricStream, OneTrust – Tự động hóa quá trình theo dõi khắc phục rủi ro

Bảng 1-1 Tổng kết các chức năng chính cho từng giai đoạn

1.3. Tính ưu việt của CTEM

1.3.1. Tính ưu việt

Dưới đây là bảng phân tích tính ưu việt của phương pháp CTEM so với phương pháp tiếp cận truyền thống.

Tiêu chí	Mô hình CTEM
Cách tiếp cận mỗi đe dọa	Chủ động khảo sát các điểm yếu và mối đe dọa tiềm ẩn để ngăn chặn các cuộc tấn công trước khi chúng xảy ra.
Phạm vi đánh giá bảo mật	Xem xét toàn bộ bề mặt tấn công, bao gồm mạng, ứng dụng, thiết bị, cơ sở hạ tầng vật lý và thậm chí mở rộng sang các nhà cung cấp bên thứ ba
Tính liên tục và cập nhật	Liên tục cập nhật về các lỗ hổng của hệ thống một cách thường xuyên, đồng thời thu thập thông tin mới về các lỗ hổng
Tính ưu tiên	Xếp hạng các lỗ hổng theo hậu quả tiềm ẩn và khả năng khai thác, hướng nguồn lực vào những rủi ro nghiêm trọng nhất
Tự động hóa	Tự động hóa cho các chức năng như thu thập dữ liệu, phát hiện lỗ hổng và các biện pháp ứng phó, do đó nâng cao cả hiệu quả và hiệu suất.
Tính liên tục	Giám sát liên tục các mối đe dọa và lỗ hổng, cung cấp thông tin chi tiết tức thời và thời gian phản hồi nhanh chóng.

Bảng 1-2 So sánh CTEM với các giải pháp truyền thống

Kết luận:

CTEM giúp tổ chức chủ động quản lý rủi ro an ninh mạng một cách hệ thống và hiệu quả. Khác với phương pháp truyền thống thụ động, CTEM cung cấp cách tiếp cận thực tế để ưu tiên và giảm thiểu các mối đe dọa quan trọng nhất thông qua giám sát liên tục.

CTEM không chỉ giúp tổ chức phản ứng nhanh hơn mà còn đón đầu các mối đe dọa mới, đảm bảo an ninh bền vững trong môi trường mạng đang không ngừng thay đổi.

1.3.2. So sánh với các phương pháp quản lý lỗ hổng cụ thể

CTEM – Quản lý lỗ hổng dựa trên rủi ro (RBVM)

Quản lý Lỗ hổng Dựa trên Rủi ro (RBVM) là một chiến lược an ninh mạng được thiết kế để hạn chế rủi ro thông qua việc ưu tiên khắc phục lỗ hổng. Hệ thống đánh giá các lỗ hổng an ninh mạng hiện có và xác định mức độ rủi ro mà mỗi lỗ hổng gây ra cho các tài sản dựa trên việc khai thác lỗ hổng đã biết "trong thực tế". Tuy nhiên, RBVM chỉ giới hạn ở việc ưu tiên các lỗ hổng (CVE) nhưng không giải quyết được các vấn đề về danh tính và cấu hình sai mà kẻ tấn công thường xuyên khai thác.

Trong khi đó, CTEM không chỉ kế thừa ưu điểm của RBVM trong việc ưu tiên rủi ro mà còn tích hợp giám sát liên tục, đánh giá đa chiều và phản ứng nhanh với các mối đe dọa đang phát triển. Nhờ đó giúp chủ động hơn trong việc giảm thiểu rủi ro tổng thể thay vì chỉ tập trung vào từng lỗ hổng riêng lẻ[7].

CTEM - Red Team Exercises

Các Red Team Exercises được thực hiện để đạt được các mục tiêu cụ thể, chẳng hạn như đánh giá khả năng của kẻ tấn công trong việc tiếp cận các ứng dụng quan trọng của doanh nghiệp. Điều này rất hữu ích trong việc xác định và phát hiện cách tấn công vào các tài sản và kiểm tra khả năng phát hiện kẻ tấn công. Tuy nhiên, chúng là những bài

tập thủ công, tốn kém và chỉ được thực hiện định kỳ. Hơn nữa, chúng không phát hiện ra tất cả các cách tấn công có thể xảy ra, hoặc ưu tiên các bản sửa lỗi cần thiết để ngăn chặn chúng[7].

Mặt khác, CTEM cung cấp phân tích toàn diện và liên tục về các biện pháp phòng thủ; ưu tiên các nỗ lực khắc phục để củng cố chúng và theo dõi sự cải thiện theo thời gian. Tuy cả hai giải pháp đều tốt cho việc kiểm tra các hệ thống phòng thủ hiện có, Red Team Exercises lại kém hiệu quả trong việc đưa ra các khuyến nghị về tư thế thường xuyên và toàn diện[7].

CTEM – Kiểm thử thâm nhập

Kiểm thử xâm nhập tương tự như các bài tập Red Team ở chỗ cả hai đều sử dụng phương pháp kiểm thử để đánh giá khả năng phòng thủ mạng của một tổ chức. Tuy nhiên, kiểm thử xâm nhập thường được thực hiện định kỳ trong các khung thời gian đã được xác định rõ ràng và thường tìm kiếm các lỗ hổng đã biết. Kiểm thử xâm nhập đánh giá khả năng bị xâm nhập của các ứng dụng, mạng, nền tảng và hệ thống, đồng thời được sử dụng để tìm ra các vấn đề cần giải quyết[7].

Mặt khác, CTEM cung cấp một phân tích toàn diện, liên tục về các biện pháp phòng thủ; ưu tiên các nỗ lực khắc phục để củng cố chúng; và theo dõi sự cải thiện theo thời gian[7].

CTEM – Giải pháp IAM và ITDR

Các giải pháp Quản lý Danh tính và Truy cập (Identity and Access Management) và Phát hiện và Ứng phó Mối đe dọa Danh tính (Identity threat detection and response) tập trung chủ yếu vào danh tính. Đây là những yếu tố then chốt đối với an ninh của một tổ chức, vì hầu hết các cuộc tấn công đều lợi dụng lỗ hổng danh tính ở đâu đó trên đường tấn công. Tuy nhiên, chúng không bao gồm việc đánh giá các nguy cơ không liên quan

đến danh tính, hoặc bất kỳ khả năng nào để xác định các đường tấn công tiềm ẩn vào các tài sản quan trọng. Do đó, tầm nhìn của chúng về môi trường của một tổ chức khá hạn chế[7].

Giải pháp CTEM phân tích toàn bộ môi trường và bao quát một loạt các mối đe dọa rộng hơn. Giải pháp này cung cấp một phân tích toàn diện, liên tục về các biện pháp phòng thủ; ưu tiên các nỗ lực khắc phục để củng cố chúng; và theo dõi sự cải thiện theo thời gian[7].

CTEM - Quản lý bề mặt tấn công bên ngoài (EASM)

Quản lý Bề mặt Tấn công Bên ngoài (EASM) là quá trình liên tục phát hiện và kiểm kê các rủi ro tiềm ẩn của tài sản bên ngoài. Quá trình này tập trung hoàn toàn vào các điểm tấn công ban đầu - "bề mặt bên ngoài" của môi trường CNTT. Do đó, quá trình này được thực hiện từ bên ngoài môi trường của bạn và không cung cấp thông tin chi tiết về các bước tiếp theo mà kẻ tấn công sẽ thực hiện sau lần tấn công ban đầu đó[7].

CTEM nhìn sâu hơn bề mặt để hiểu toàn bộ các điểm yếu trong môi trường của bạn, cũng như cách kẻ tấn công có thể kết nối các điểm yếu này thành một đường tấn công nhắm vào các tài sản quan trọng. CTEM cung cấp danh sách các điểm yếu đầy đủ hơn nhiều so với ASM, và có thể giúp bạn đánh giá rủi ro an ninh mạng một cách có ý nghĩa hơn. Hơn nữa, CTEM có đủ bối cảnh để ưu tiên các điểm yếu đó cho bạn, giúp bạn khắc phục sự cố một cách tự tin và hiệu quả[7].

1.4. Lợi ích của việc sử dụng hệ thống CTEM

Việc triển khai Continuous Threat Exposure Management (CTEM) mang lại nhiều lợi ích quan trọng cho tổ chức trong công tác quản lý và ứng phó an ninh mạng:

- *Quản lý rủi ro chủ động, thay vì bị động*: CTEM giúp tổ chức liên tục phát hiện, đánh giá và xử lý các điểm phơi nhiễm bảo mật trước khi chúng bị khai thác bởi kẻ tấn công.
- *Ưu tiên hóa thông minh theo rủi ro thực tế*: giúp tổ chức tập trung nguồn lực đúng chỗ, xử lý những rủi ro có tác động lớn nhất.
- *Toàn diện bề mặt tấn công*: giúp tránh bỏ sót các lỗ hổng hoặc tài sản “ẩn” không nằm trong tầm nhìn truyền thống
- *Tăng khả năng hiển thị và hiểu biết toàn diện về hệ thống*: CTEM cung cấp cái nhìn tổng thể, liên tục và cập nhật về các tài sản.
- *Cải thiện khả năng phản ứng và thời gian khắc phục*: CTEM giúp phát hiện sớm và xác định rõ lỗ hổng quan trọng. Nhờ đó giảm được thời gian phát hiện lỗ hổng (MTTD) và rút ngắn thời gian xử lý và vá lỗi (MTTR)
- *Giảm chi phí*: Một chương trình CTEM có thể giúp giảm thiểu rủi ro, cải thiện tình hình an ninh , tận dụng tự động hóa và giảm thiểu hậu quả của vi phạm một cách hiệu quả, có thể tiết kiệm được rất nhiều tiền bạc và công sức về lâu dài.

1.5. Những thách thức khi triển khai hệ thống CTEM

Bên cạnh những lợi ích rõ rệt, việc triển khai Continuous Threat Exposure Management (CTEM) trong thực tế cũng đặt ra nhiều thách thức cho tổ chức:

- *Thiếu kỹ năng chuyên môn*: CTEM đòi hỏi sự kết hợp nhiều kỹ năng từ kỹ thuật an ninh mạng, quản lý rủi ro cho đến tuân thủ và pháp lý. Điều này có thể tạo ra thách thức khi các tổ chức không có đủ chuyên gia hoặc cần đầu tư đào tạo và nâng cao kỹ năng nhân viên hiện tại[1].
- *Thiếu sự hiểu biết và hợp tác giữa các nhóm*: Việc đảm bảo mọi bên liên quan đều hiểu và phối hợp hiệu quả trong quá trình triển khai CTEM là một thách thức không nhỏ, đặc biệt khi các mục tiêu kinh doanh và công nghệ cần được hài hòa[1].

- *Giới hạn về nguồn lực và ngân sách:* Phạm vi của CTEM cao hơn các phương pháp tiếp cận truyền thống. Các tổ chức có thể cần phải bảo vệ lỗ hổng của các nguồn tài nguyên kỹ thuật số bổ sung. Điều này có thể đòi hỏi đầu tư đáng kể vào nhân sự cơ sở hạ tầng và tài nguyên tính toán[1].

Chương 2 Giới thiệu một số nền tảng CTEM

2.1. Nanitor

2.1.1. Giới thiệu



Hình 2-1 Logo Nanitor

Nền tảng Nanitor là một nền tảng CTEM cấp doanh nghiệp hàng đầu, được thiết kế để cung cấp khả năng hiển thị và kiểm soát chưa từng có đối với cơ sở hạ tầng CNTT toàn cầu của tổ chức. Nanitor cung cấp khả năng phân tích tình trạng an ninh mạng cơ bản, dù là trên máy tính xách tay, máy tính để bàn, máy chủ, thiết bị mạng hay cơ sở dữ liệu.

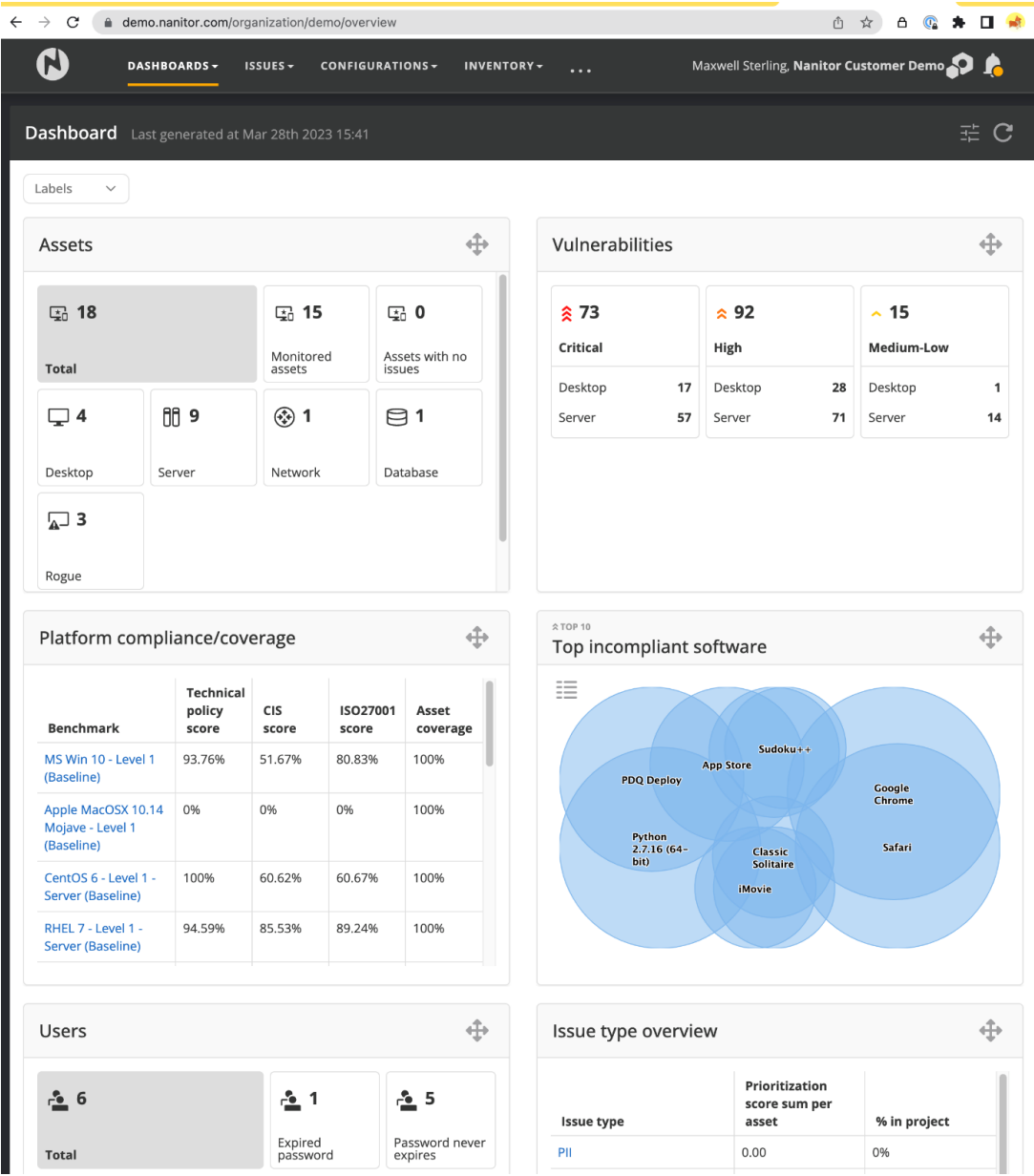
Với sự phát triển không ngừng của Nanitor, một điểm đặc biệt nổi bật đã được ra đời: Nanitor Diamond Vision. Nanitor Diamond hiển thị tổng quan trực quan ngay lập tức về tất cả các vấn đề bảo mật tiềm ẩn được tìm thấy trên hệ thống của người dùng.



Hình 2-2 Nanitor Diamond Vision

Tính năng này được thiết kế để giải quyết một trong những thách thức lớn nhất của các đội ngũ an ninh mạng hiện nay - sự quá tải thông tin. Nanitor Diamond Vision giúp lọc và ưu tiên hàng nghìn vấn đề tiềm ẩn, chỉ ra những rủi ro thực sự nghiêm trọng và có khả năng bị khai thác cao nhất trong môi trường của doanh nghiệp.

Dưới đây là hình ảnh về giao diện của một số tính năng có trong Nanitor:



Hình 2-3 Overview dashboard

Assets Inventory

Apply label to all

Add new asset

Total: 35

Search by Hostname or I...

Health status

Active, Inactive, Pending...

Desktop, Server, Laptop

Label

Benchmark

OS

Has issues?

Has benchmark?

More +

Reset

☐	Hostname	State	Highest Asset Priority	Type	Labels	Actions
☐	external_device1 External	Active	C I A 8	Server	Production Server	...
☐	workstation1	Active	C I A 6.3	Desktop	Desktop MacOS Workstation	...

<<

<

1

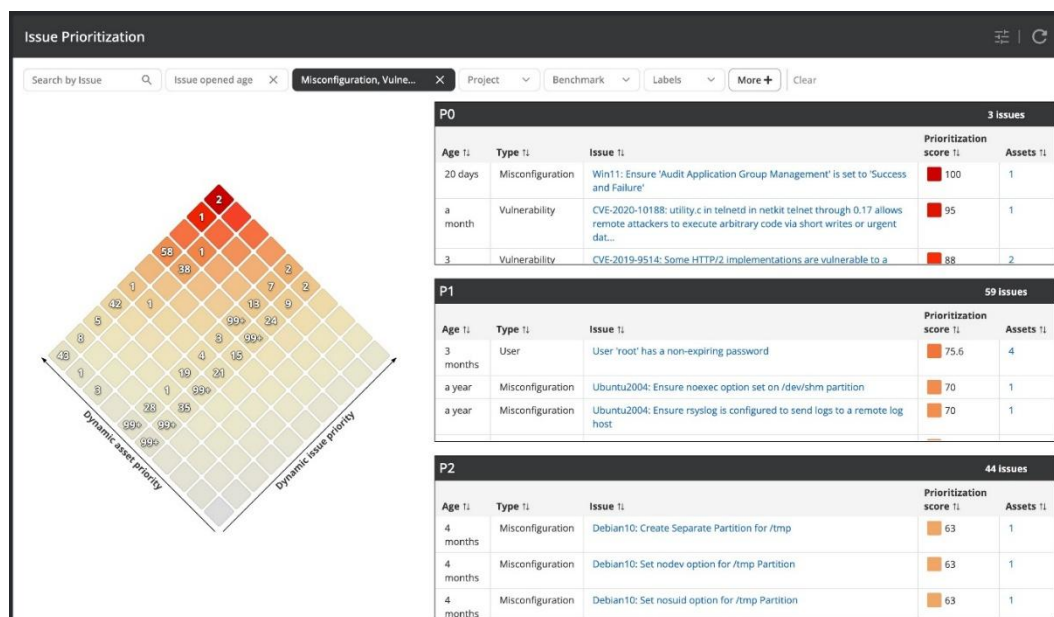
>

>>

Hình 2-4 Nanitor – Assets Inventory

Issues									
Search by issue P0, P1 Misconfiguration, Patch... Project Labels Benchmark More + Clear									
☐	Issue	Open since	Type	Issue Priority	NPS	Assets	Projects	Action	
☐	#1827: Win11: Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled'	Feb 23rd 2023 19:37	Misconfiguration	C 7 I 7 A 7	70	1	☒ Windows configuration most impactfu	...	5
☐	#1837: Win11: Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block (default)'	Feb 23rd 2023 19:37	Misconfiguration	C 7 I 7 A 7	70	1	☒ Windows configuration most impactfu	...	7
☐	#1842: Win11: Ensure 'Audit Application Group Management' is set to 'Success and Failure'	Feb 23rd 2023 19:37	Misconfiguration	C 10 I 10 A 10	100	1	☐ No	...	
☐	#289: Ubuntu2004: Ensure rsyslog is configured to send logs to a remote log host	Apr 4th 2022 14:54	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#292: Ubuntu2004: Ensure permissions on /etc/cron.daily are configured	Apr 4th 2022 14:54	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#179: User 'root' has a non-expiring password	Nov 30th 2022 17:24	User	C 8.4 I 8.4 A 8.4	75.6	4	☐ No	...	
☐	#1128: IBM_ADX7.1_9172097070: /etc/security/user - maxage	Jan 25th 2023 13:44	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#1130: IBM_ADX7.1_0687843247: /etc/security/user - minalpha	Jan 25th 2023 13:44	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#1134: IBM_ADX7.1_7017258974: /etc/security/user - histsize	Jan 25th 2023 13:44	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#1136: IBM_ADX7.1_2630138190: /etc/security/user - minloweralpha	Jan 25th 2023 13:44	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	
☐	#1148: IBM_ADX7.1_9799085117: Miscellaneous	Jan 25th 2023 13:44	Misconfiguration	C 7 I 7 A 7	70	1	☐ No	...	

Hình 2-5 Nanitor – Issues List



Hình 2-6 Nanitor – Prioritization

2.1.2. Các giải pháp chính

Giải pháp	Chức năng cụ thể
Khám phá tài sản	1. Kiểm kê người dùng 2. Kiểm kê thiết bị 3. Kiểm kê Phần mềm
Quản lý các thành phần bảo mật	1. Quản lý Cấu hình 2. Quản lý Lỗ hổng bảo mật 3. Quản lý Bản vá

Bảng 2-1 Các giải pháp chính của Nanitor

2.2. Tenable

2.2.1. Giới thiệu

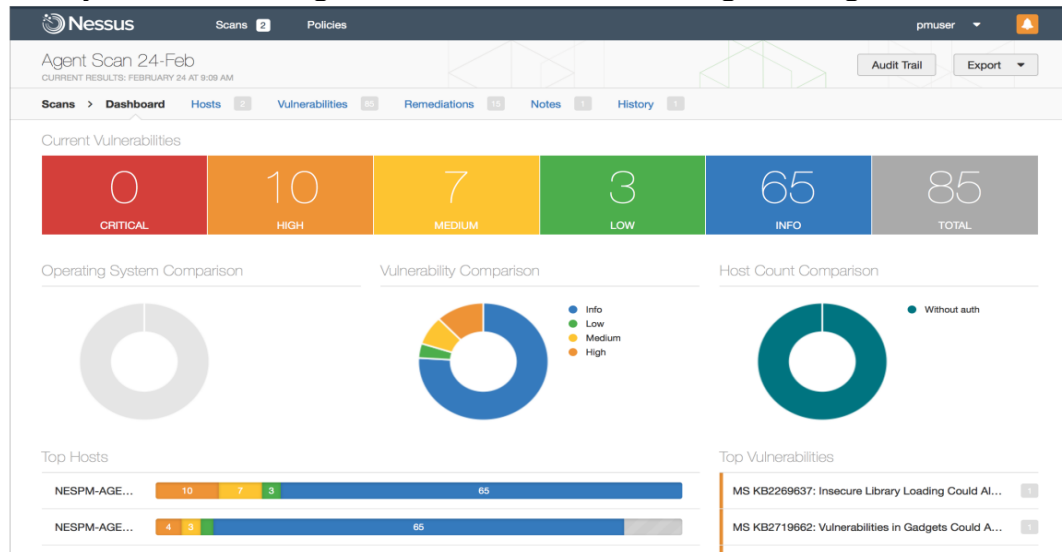


Hình 2-7 Logo Tenable

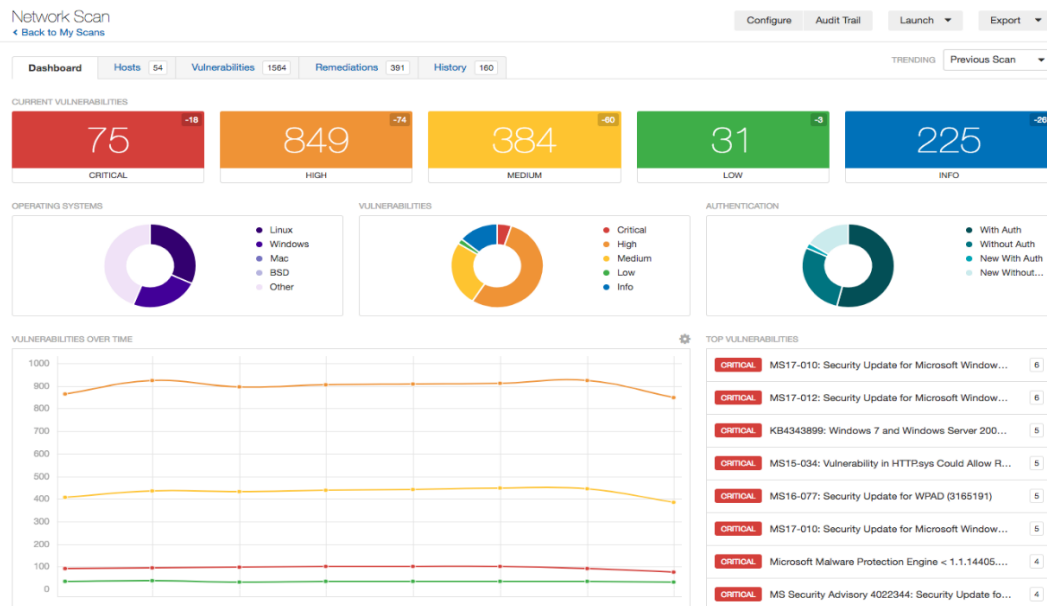
Tenable ra đời để phát hiện và khắc phục các lỗ hổng bảo mật ưu tiên gây rủi ro cho doanh nghiệp. Bằng cách bảo vệ cơ sở hạ tầng kỹ thuật số và quan trọng khỏi các rủi ro, Tenable giảm thiểu rủi ro kinh doanh cho hơn 44.000 khách hàng trên toàn cầu.

Tenable sở hữu một công cụ quét lỗ hổng bảo mật độc quyền là Nessus. Với hơn 20 năm phát triển, Nessus đã trở thành một trong những sản phẩm hàng đầu trong lĩnh vực quét lỗ hổng, góp phần lớn trong việc giúp các tổ chức toàn cầu bảo vệ hệ thống và tài sản khỏi các cuộc tấn công mạng.

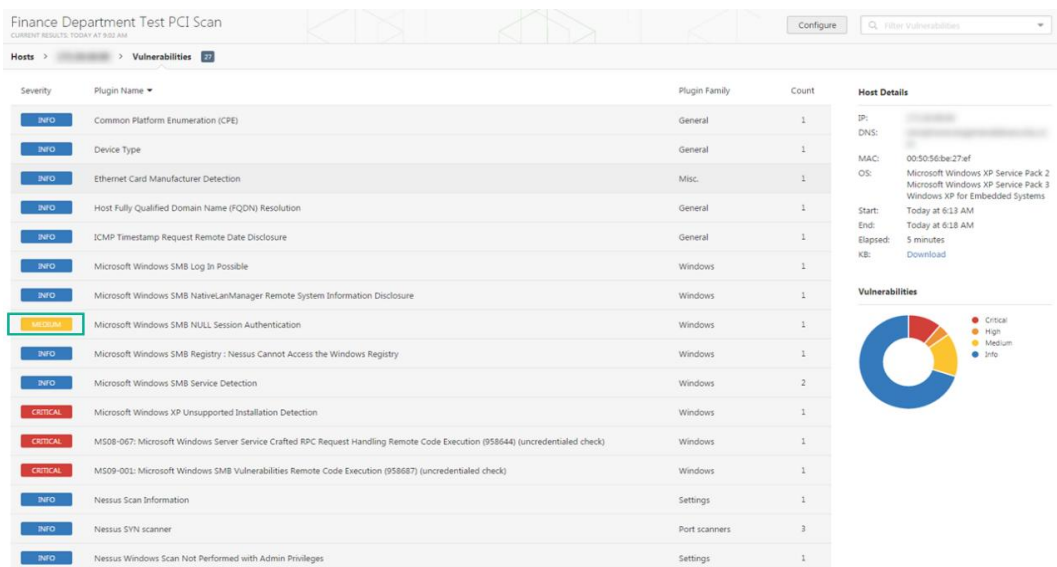
Dưới đây là hình ảnh về giao diện của một số tính năng có trong Tenable Nessus:



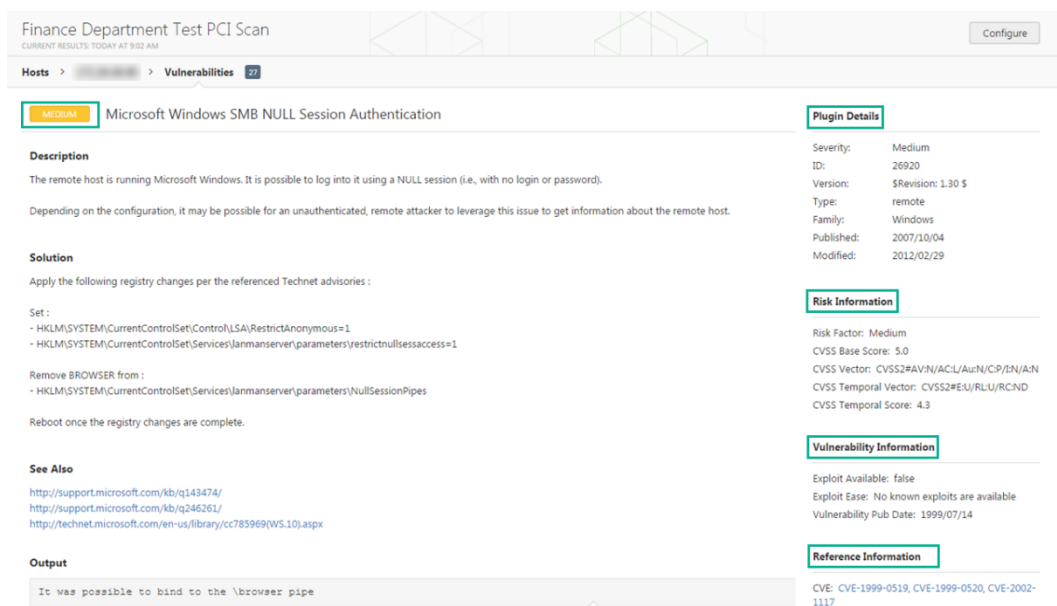
Hình 2-8 Tenable Nessus – Overview dashboard



Hình 2-9 Tenable Nessus – Show scan result in dashboard view



Hình 2-10 Tenable Nessus – List of a single host's scan results



Hình 2-11 Tenable Nessus – Details of a single host's plugin scan result

2.2.2. Các giải pháp chính

Giải pháp	Chức năng cụ thể
Bảo mật hạ tầng và nền tảng đám mây	1. AWS security 2. Azure security 3. Google Cloud security 4. Quản lý tư thế bảo mật đám mây (CSPM) 5. Bảo mật Cơ sở hạ tầng dưới dạng Mã (IaC)
Quản lý các thành phần bảo mật	1. Quản lý lỗ hổng 2. Đánh giá lỗ hổng 3. Ransomware
Giải pháp chuyên biệt/ nâng cao	1. Quản lý tư thế bảo mật AI (AI-SPM) 2. Quản lý tư thế bảo mật dữ liệu (DSPM)

Bảng 2-2 Các giải pháp chính của Tenable

2.3. XM Cyber

2.3.1. Giới thiệu



Hình 2-12 Logo XM Cyber

XM Cyber là một công ty bảo mật đám mây lai hàng đầu, thuộc Tập đoàn Schwarz, chuyên giúp các tổ chức quản lý rủi ro mạng. Nền tảng của họ tập trung vào việc liên tục

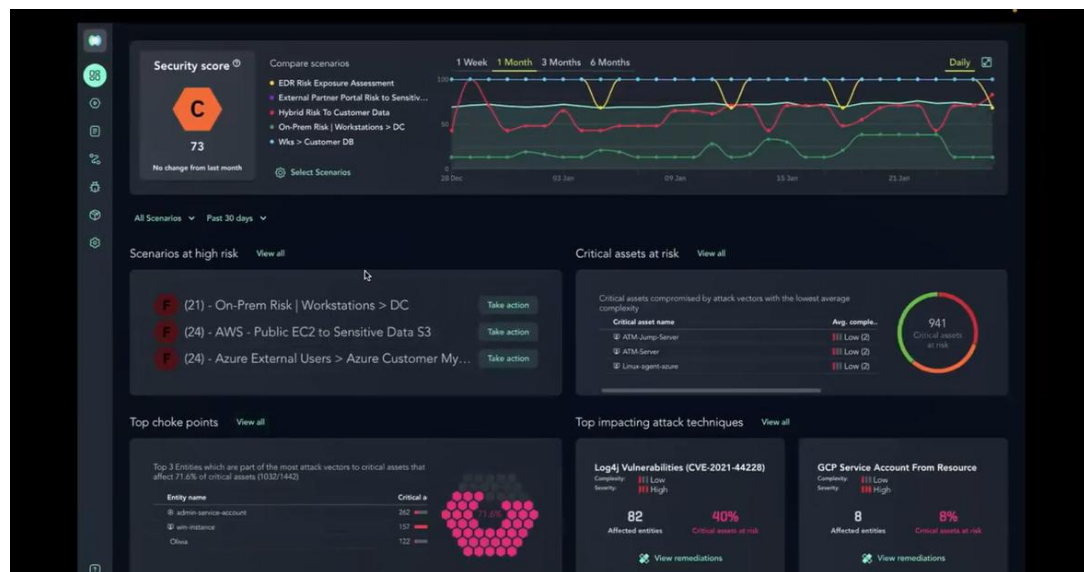
theo dõi và phát hiện các lỗ hổng trên cả môi trường nội bộ và đám mây, giúp khách hàng nhìn thấy các con đường tấn công tiềm năng và ngăn chặn chúng.

Một trong những điểm đặc biệt nhất của XM Cyber là khả năng xác định các "Choke Points" – điểm nghẽn. Bằng cách khắc phục điểm nghẽn, nhiều điểm yếu khác sẽ trở nên không còn liên quan và không còn gây rủi ro cho doanh nghiệp nữa.

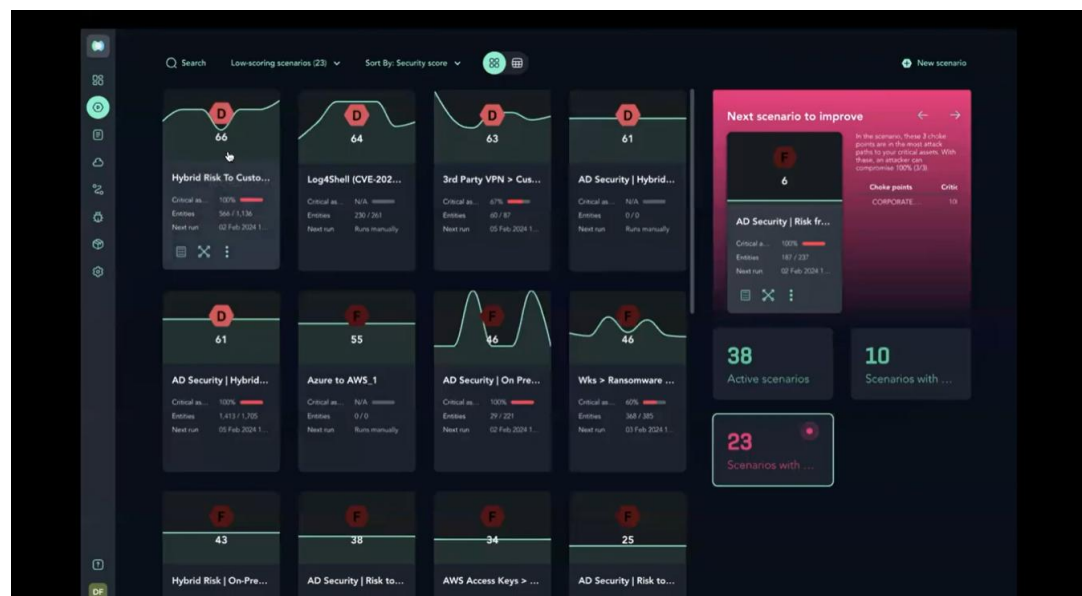


Hình 2-13 XM Cyber Choke point

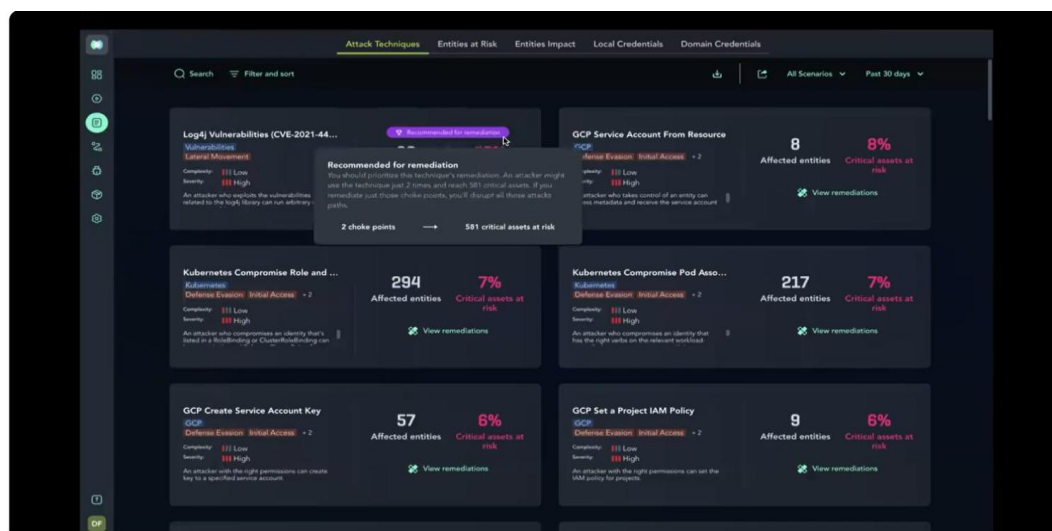
Dưới đây là hình ảnh về giao diện của một số tính năng có trong XM Cyber:



Hình 2-14 XM Cyber – Overview dashboard



Hình 2-15 XM Cyber – Scenario Hubs



Hình 2-16 XM Cyber - Report

2.3.2. Các giải pháp chính

Giải pháp	Chức năng cụ thể
Quản lý lỗ hổng và rủi ro	1. Đánh giá lỗ hổng 2. Tối ưu hóa phòng thủ chủ động 3. Sẵn sàng chống phần mềm ransomware
Kiểm soát bảo mật liên tục	1. Xác thực bảo mật tự động 2. Giám sát kiểm soát liên tục 3. Tối ưu hóa phòng thủ chủ động

Bảng 2-3 Các giải pháp chính của XM Cyber

So sánh

	Điểm mạnh	Điểm yếu
Nanitor	- Thiết kế tối ưu giúp ưu tiên các vấn đề theo tài sản và tác động thực tế - Giá cả hợp lý, dễ sử dụng, hỗ trợ khách hàng tốt - Phân loại rủi ro theo mức độ severity, cấu hình sai, patch, license... và kèm báo cáo	- Chưa phổ biến như Tenable hay XM Cyber - Có thể thiếu một số tính năng cho enterprise lớn
Tenable	- Dựa trên Nessus – công cụ quét lỗ hổng hàng đầu - Tích hợp đám mây và devsecops - Thương hiệu rất mạnh, rộng rãi trong tổ chức lớn toàn cầu.	Chủ yếu tập trung vào lỗ hổng và scan; chưa có mô phỏng attack path hay validation exploit
XM Cyber	- Mô phỏng tấn công liên tục - Ưu tiên rủi ro theo ngữ cảnh - Xác minh lỗ hổng có thể bị kẻ tấn công khai thác không	- Chi phí triển khai cao, phù hợp tổ chức lớn. - Tùy chỉnh và cấu hình khá phức tạp

Bảng 2-4 Bảng so sánh các nền tảng CTEM

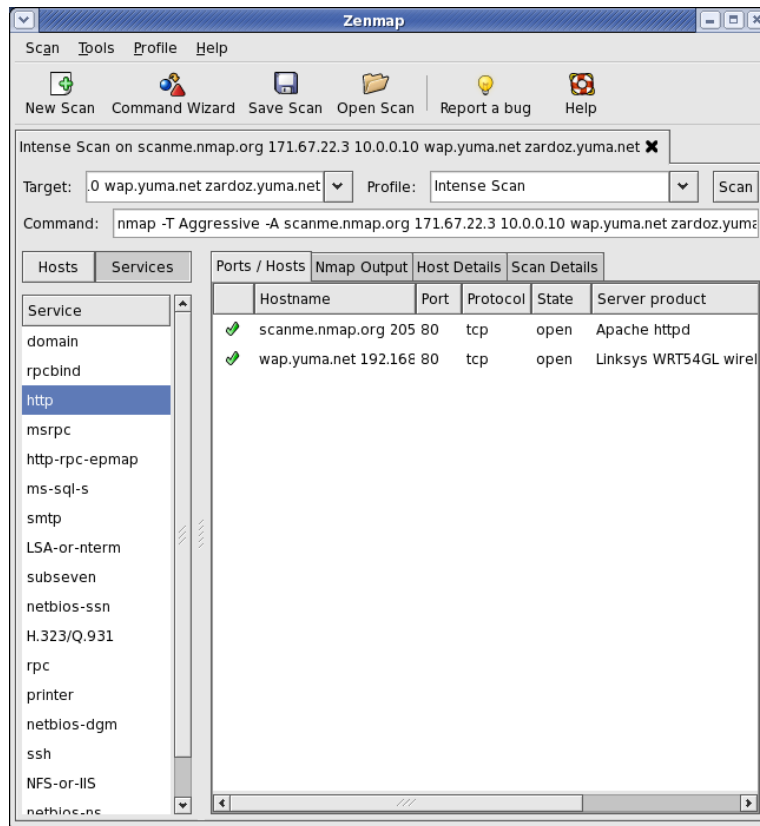
Chương 3 Các công cụ hỗ trợ

3.1. Nmap



Hình 3-1 Logo Nmap

Nmap (tên đầy đủ Network Mapper) là một công cụ bảo mật được phát triển bởi Floydor Vaskovitch. Nmap có mã nguồn mở, miễn phí, dùng để quét cổng và lỗ hổng bảo mật. Các chuyên gia quản trị mạng sử dụng Nmap để xác định xem thiết bị nào đang chạy trên hệ thống của họ, cũng như tìm kiếm ra các máy chủ có sẵn và các dịch vụ mà các máy chủ này cung cấp, đồng thời dò tìm các cổng mở và phát hiện các nguy cơ về bảo mật.



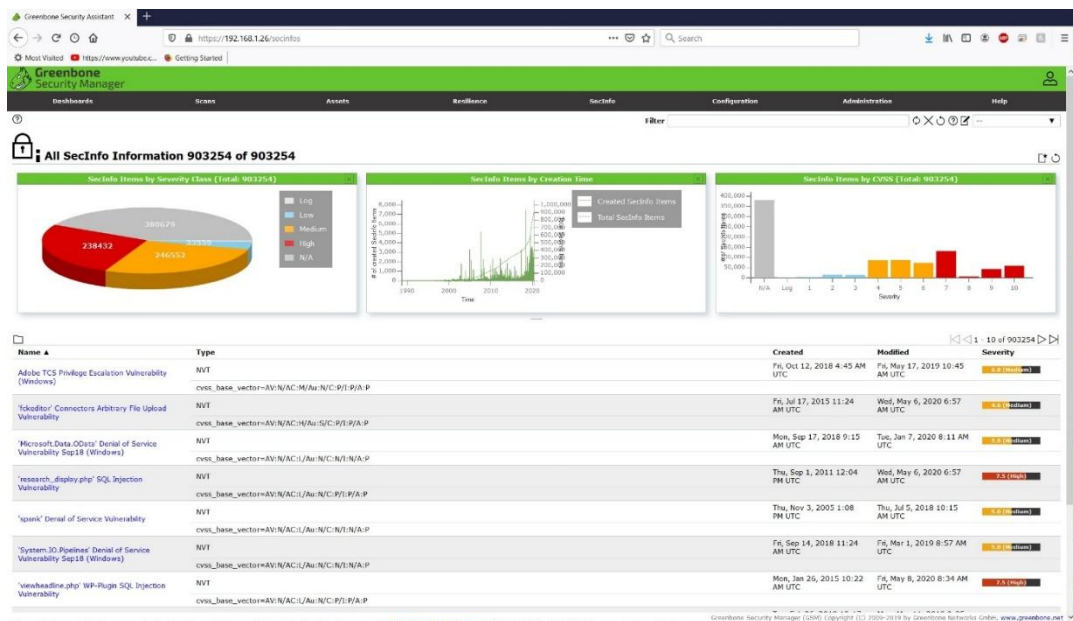
Hình 3-2 Zenmap – GUI của Nmap

3.2. OpenVAS



Hình 3-3 Logo openVAS

OpenVAS là một trình quét lỗ hổng bảo mật đầy đủ tính năng. Khả năng của nó bao gồm kiểm tra xác thực và không xác thực, nhiều giao thức internet và công nghiệp cấp cao và cấp thấp, tinh chỉnh hiệu năng cho các lần quét quy mô lớn và một ngôn ngữ lập trình nội bộ mạnh mẽ để triển khai bất kỳ loại kiểm tra lỗ hổng nào.



Hình 3-4 GUI của OpenVAS Greenbone

3.3. Metasploit Framework

Metasploit Framework là một nền tảng mã nguồn mở cho việc phát triển, thử nghiệm và sử dụng các kỹ thuật tấn công mạng. Được phát triển bởi Rapid7, Metasploit cung cấp cho các chuyên gia bảo mật, nhà nghiên cứu và hacker đạo đức một tập các công cụ khai thác lỗ hổng để kiểm tra tính bảo mật của các hệ thống và ứng dụng.

Tổng kết

Bảng dưới đây liệt kê các chức năng của hệ thống sử dụng các công cụ trên:

Công cụ	Chức năng
Nmap	• Quét các port và dịch vụ chạy trên port • Phát hiện hệ điều hành
OpenVAS	Quét lỗ hổng trên các host
Metasploit Framework	Khai thác lỗ hổng tự động

Bảng 3-1 Bảng tổng kết các công cụ hỗ trợ

Chương 4 Xây dựng hệ thống

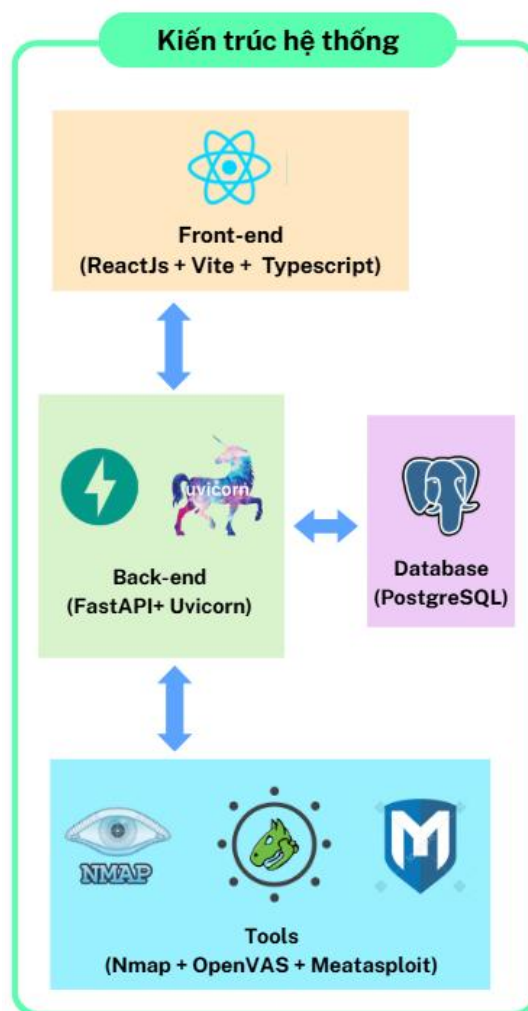
4.1. Các công nghệ được sử dụng

Công cụ	Chức năng
ReactJS+Vite+TypeScript	Xây dựng front-end
FastAPI	Cung cấp phần ứng dụng web
Uvicorn	• Chạy server cho back-end • Nhận kết nối HTTP từ client và chuyển tiếp request cho FastAPI
PostgreSQL	Đóng vai trò database lưu kết quả quét

Bảng 4-1 Bảng tổng kết các công nghệ sử dụng

4.2. Kiến trúc hệ thống

4.2.1. Tổng quan



Hình 4-1 Kiến trúc hệ thống

Các tính năng chính

- **Quản lý tài sản** : Kiểm kê và theo dõi tất cả tài sản mạng
- **Quản lý lỗ hổng** : Xác định, theo dõi và khắc phục các lỗ hổng bảo mật

- **Giám sát tình hình bảo mật** : Bảng thông tin trực quan về số liệu sức khỏe bảo mật
- **Tích hợp quét** : Chạy và xử lý quét bảo mật đối với tài sản

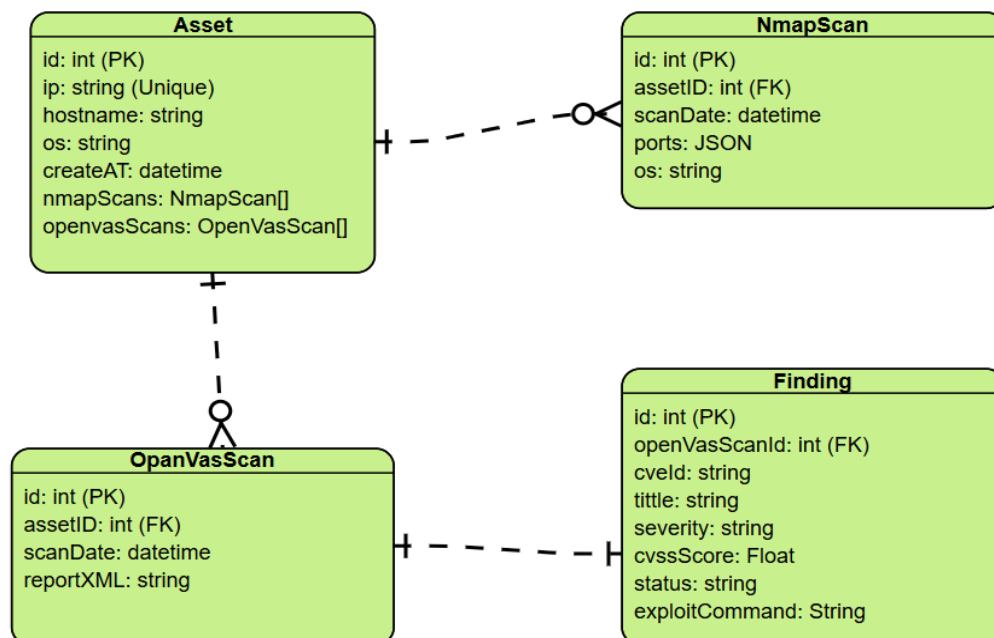
4.2.2. Kiến trúc back-end

CTEM Backend Architecture	
FastAPI Application (main.py)	
• CORS Middleware • Lifespan Management • Health Monitoring	
API Routes Layer (/api/*)	
• /api/assets – Asset Management • /api/scan – Scanning Operations • /api/parser – File/Data Parsing • /api/reports – Report Generation	• /api/findings – Vulnerability Management • /api/dashboard – Dashboard Data • /api/health – Health check endpoint
Services Layer	
• Asset Service – Asset discovery & management • Scan Service – Orchestrates scanning tools • Nmap Service – Network scanning • OpenVAS Service – Vulnerability scanning • Metasploit Framework – Exploit database search	

Database Layer
• SQLAlchemy ORM – Database abstraction • PostgreSQL – Primary database • Alembic – Database migrations
External Tools Integration
Nmap – Network discovery & port scanning OpenVAS – Vulnerability assessment Metasploit Framework– Exploit research

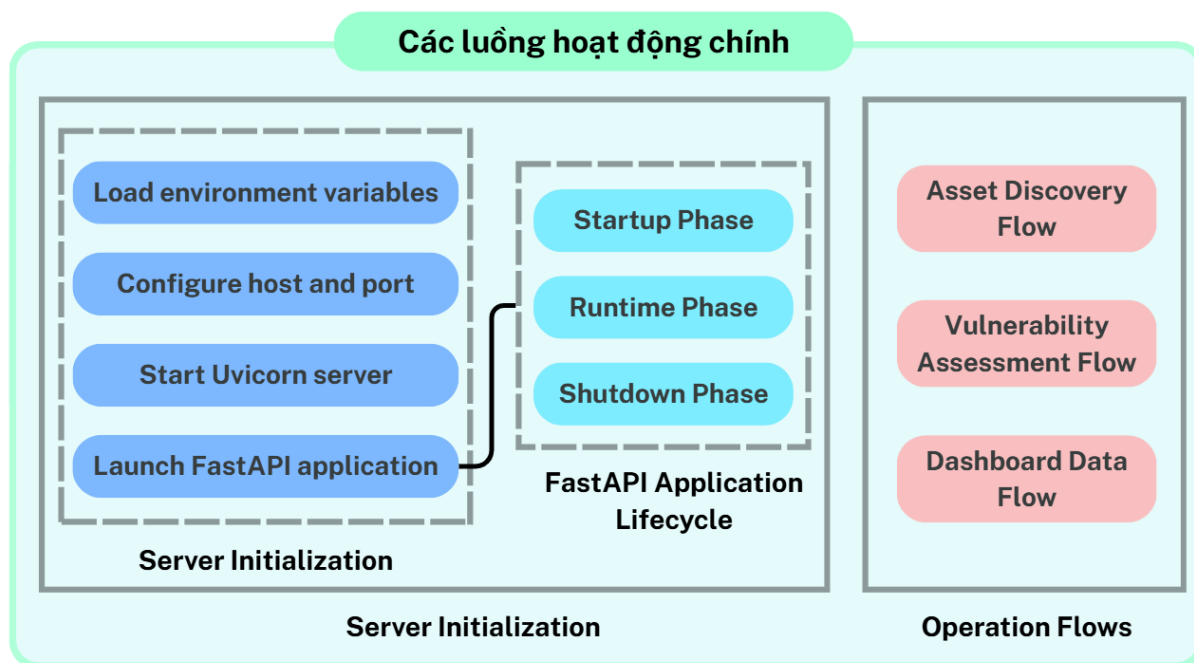
Bảng 4-2 Bảng mô tả kiến trúc back-end

4.2.3. Mô hình ERD cho database



Hình 4-2 Mô hình ERD cho database

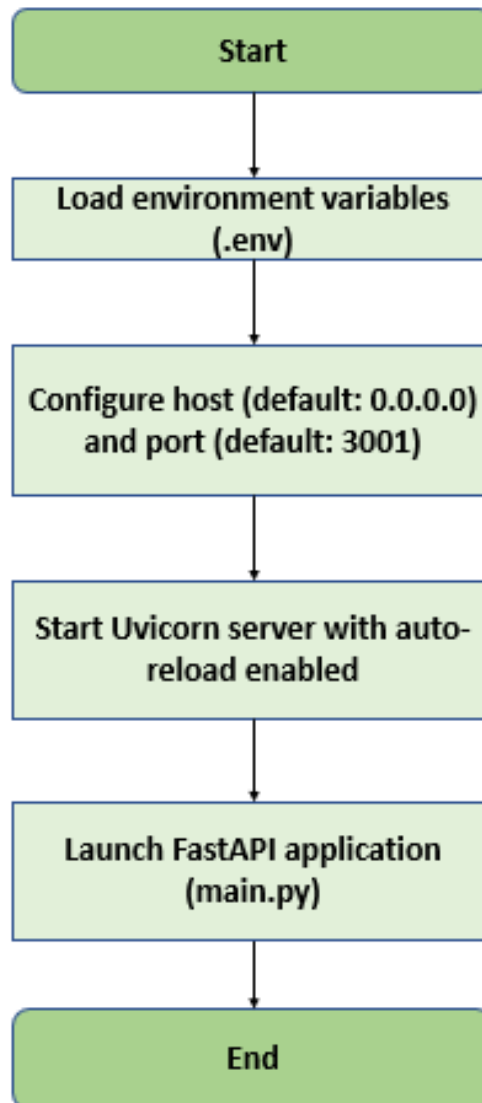
4.3. Luồng hoạt động



Hình 4-3 Luồng hoạt động chính trong hệ thống

4.3.1. Luồng hoạt động khởi động hệ thống

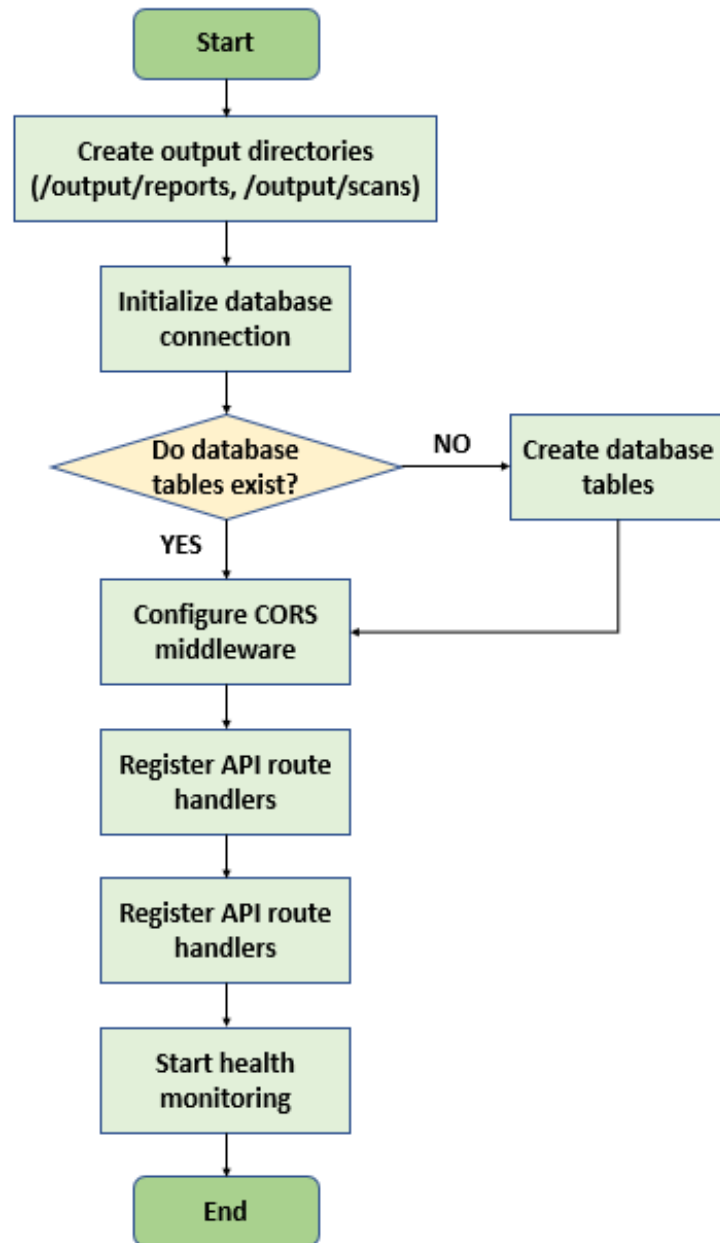
1. Khởi tạo server (start.py)



Hình 4-4 Server Initialization Flow

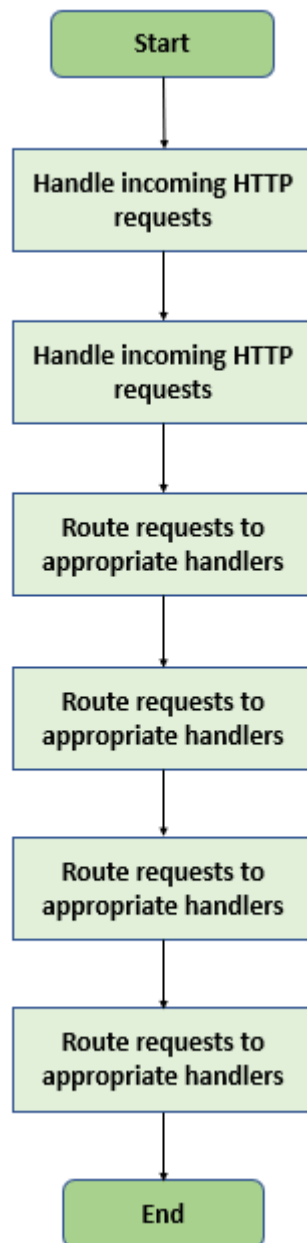
2. FastAPI Application Lifecycle

a. Startup phase



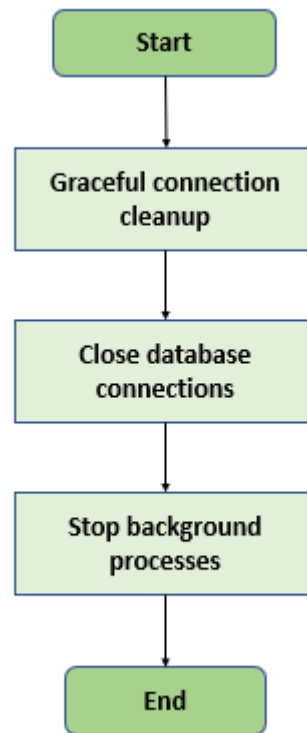
Hình 4-5 FastAPI Application Lifecycle – Startup phase

b. Runtime phase



Hình 4-6 FastAPI Application Lifecycle – Runtime phase

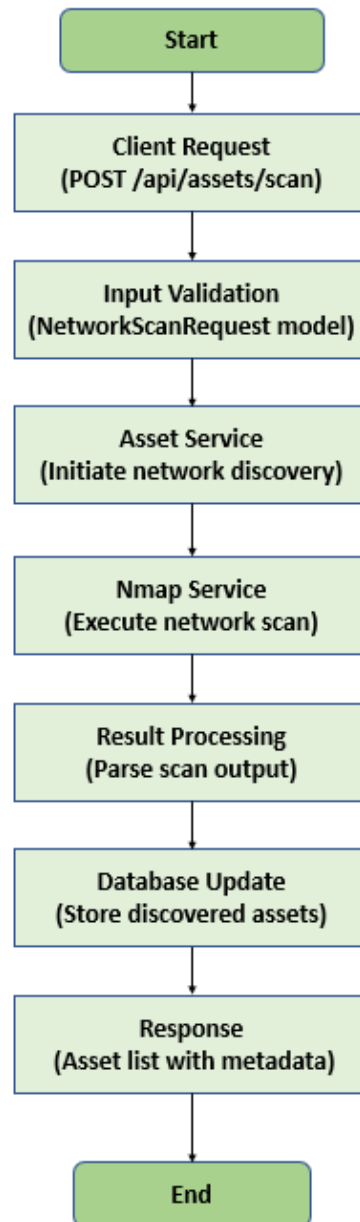
c. Shutdown phase



Hình 4-7 FastAPI Application Lifecycle – Shutdown phase

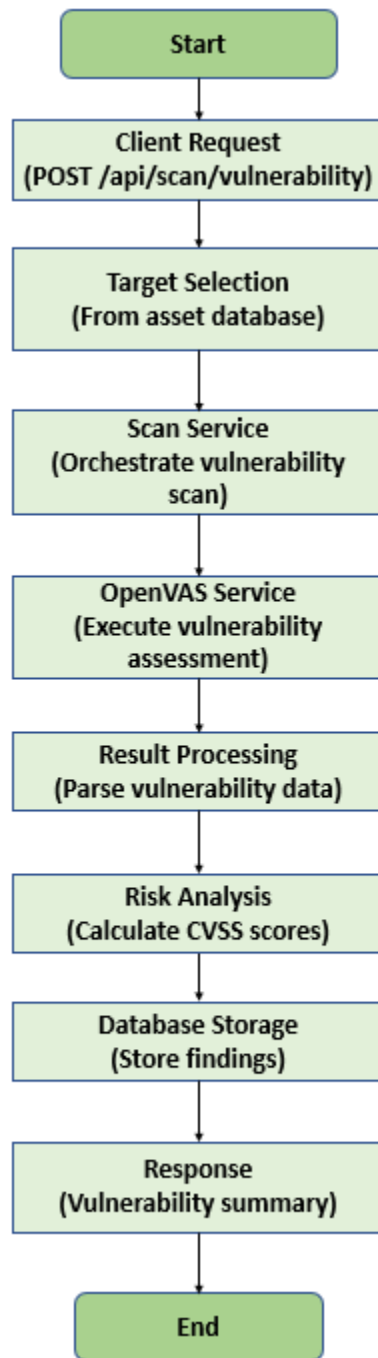
4.3.2. Luồng hoạt động của các tính năng

1. Asset Discovery



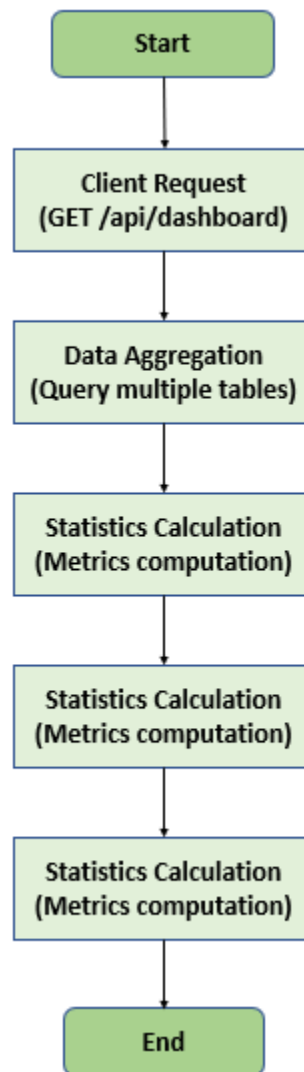
Hình 4-8 Asset Discovery Flow

2. Vulnerability Assessment



Hình 4-9 Vulnerability Assessment Flow

3. Dashboard Data



Hình 4-10 Dashboard Data Flow

Chương 5 Kết quả thực nghiệm

5.1. Môi trường kiểm thử - Metasploitable 3

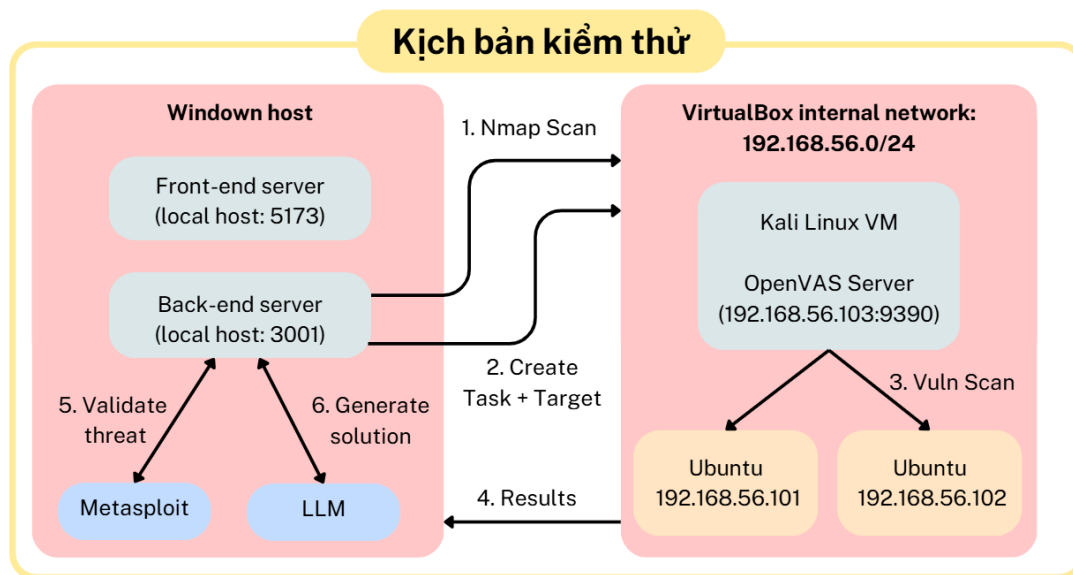
Metasploitable 3 là một máy ảo chứa nhiều lỗ hổng bảo mật nghiêm trọng, được thiết kế bởi Rapid7 để học tập, thực hành tấn công khai thác (exploitation) bằng Metasploit Framework hoặc công cụ bảo mật khác. Máy ảo này tương thích với VMWare, VirtualBox và các nền tảng ảo hóa phổ biến khác. Đây là môi trường an toàn để rèn luyện kỹ năng pentest mà không vi phạm pháp luật, được sử dụng rộng rãi trong các khóa học, CTF, và lab tự học về an ninh mạng.

5.2. Kịch bản kiểm thử

Môi trường kiểm thử sẽ bao gồm 4 máy tính hoạt động cùng lúc:

- 1 máy ảo cài đặt Metasploitable3 chạy hệ điều hành Ubuntu có địa chỉ IP là 192.168.56.101.
- 1 máy ảo cài đặt Metasploitable3 chạy hệ điều hành Windows có địa chỉ IP là 192.168.56.102.
- 1 máy ảo chạy hệ điều hành Kali Linux để làm server cho OpenVAS có địa chỉ IP là 192.168.56.103.
- 1 máy hệ điều hành Windows là nơi chứa source code và chạy server cho front-end và back-end có địa chỉ IP là 192.168.1.106 (có thể thay đổi tùy vào mạng)

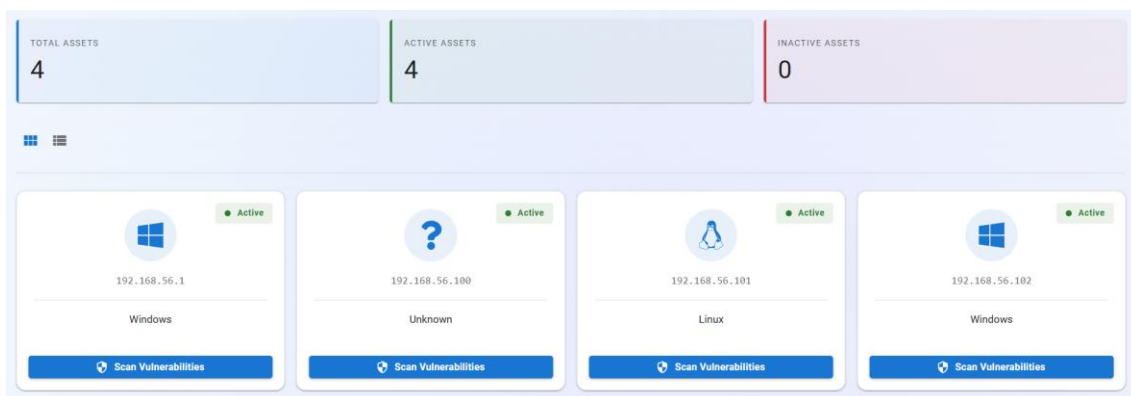
Tất cả các máy ảo đều chạy trên phần mềm ảo hóa là VirtualBox và được cấu hình network là “Host-only Adapter” nằm trong mạng nội bộ của VirtualBox với địa chỉ đường mạng là 192.168.56.0/24.



Hình 5-1 Kịch bản kiểm thử

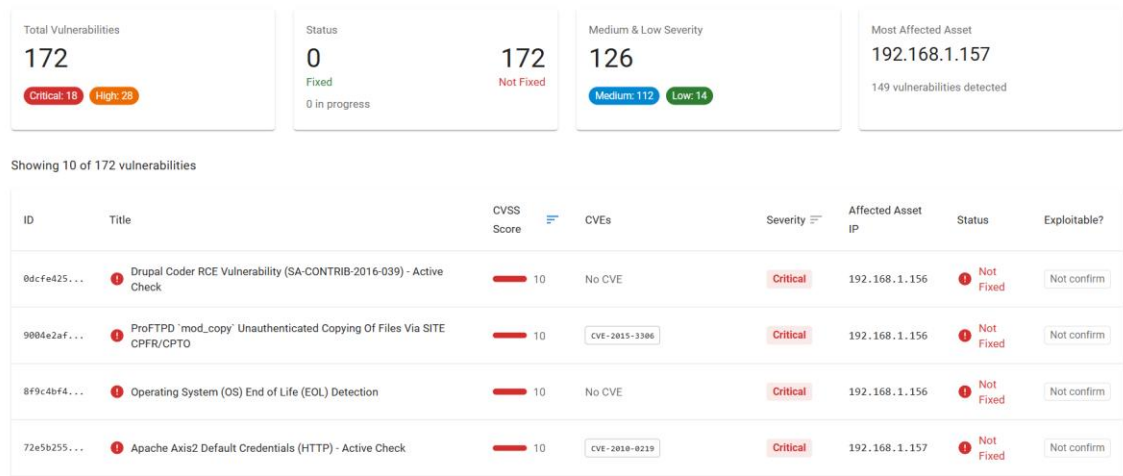
5.3. Kết quả

Kết quả scan network bằng Nmap:



Hình 5-2 Nmap Scan

Kết quả sau khi phân tích report của OpenVAS:



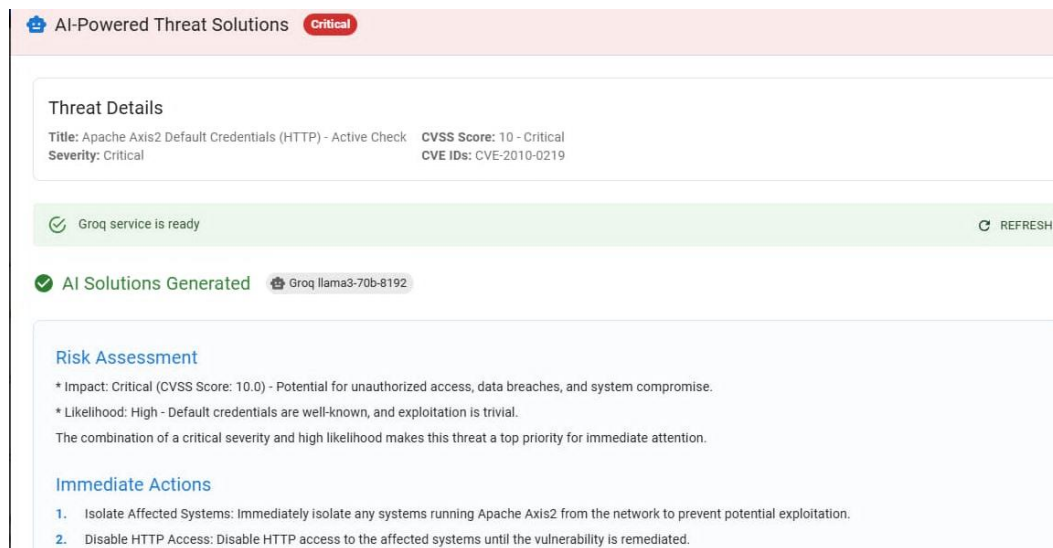
Hình 5-3 OpenVAS Scan

Kết quả sau khi validate bằng Metasploit Framework với cột Exploitable được cập nhật:

ID	Title	CVSS Score	CVEs	Severity	Affected Asset IP	Status	Exploitable?
2162...	Apache Axis2 Default Credentials (HTTP) - Active Check	10	CVE-2010-0219	Critical	192.168.56.102	Fixed	Yes
2139...	ProFTPD 'mod_copy' Unauthenticated Copying Of Files Via SITE CPFR/CPTO	10	CVE-2015-3306	Critical	192.168.56.101	Fixed	Yes
2142...	SSH Brute Force Logins With Default Credentials Reporting	9.8	CVE-2020-9473 CVE-1999-0501 +15	Critical	192.168.56.101	Fixed	Yes
2168...	SSH Brute Force Logins With Default Credentials Reporting	9.8	CVE-2020-9473 CVE-1999-0501 +15	Critical	192.168.56.102	Fixed	Yes
2172...	Microsoft Windows Remote Desktop Services RCE Vulnerability (CVE-2019-0708, BlueKeep) - Active Check	9.8	CVE-2019-0708	Critical	192.168.56.102	Fixed	Yes
2144...	Drupal Core SQLi Vulnerability (SA-CORE-2014-005) - Active Check	7.5	CVE-2014-3784	High	192.168.56.101	Fixed	Yes
2145...	FTP Brute Force Logins With Default Credentials Reporting	7.5	CVE-1999-0501 CVE-1999-0502 +12	High	192.168.56.101	Fixed	Yes

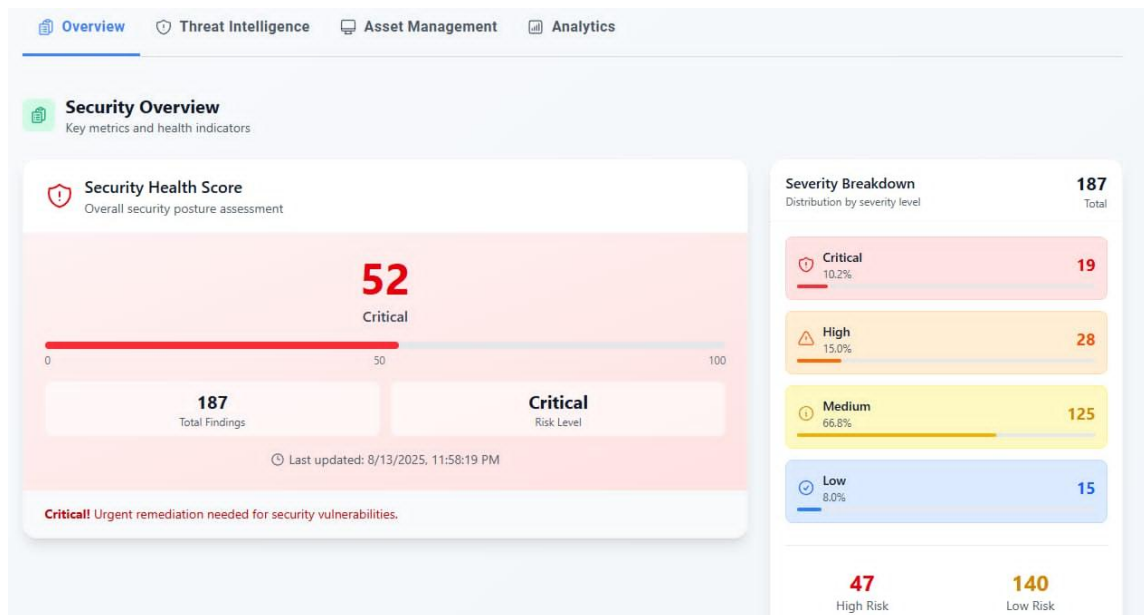
Hình 5-4 Metasploit Framework validate

Kết quả sau khi sử dụng LLM để tự động sinh ra solution:



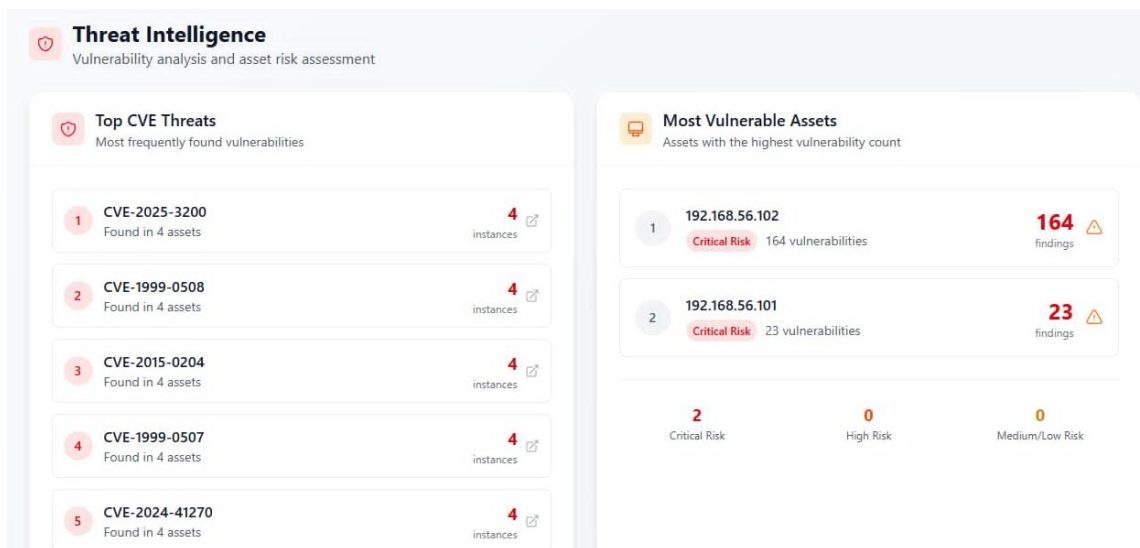
Hình 5-5 LLM solution

Trang DashBoard Overview, thông kê số lượng từng lỗ hổng theo mức độ:



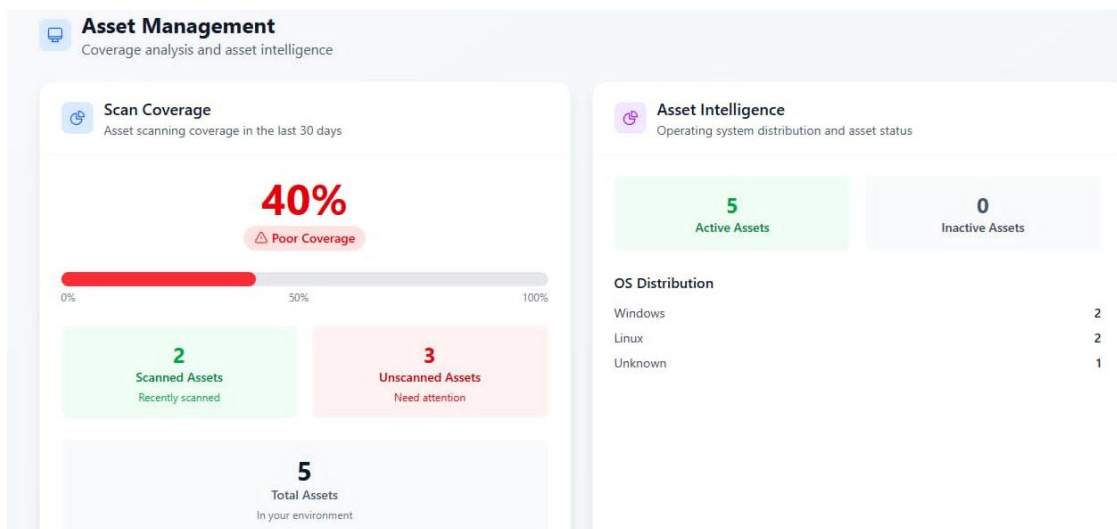
Hình 5-6 Dashboard Overview

Trang DashBoard, mục Threat Intelligence thống kê số lượng CVE xuất hiện nhiều nhất và Asset chứa nhiều lỗ hổng nhất:

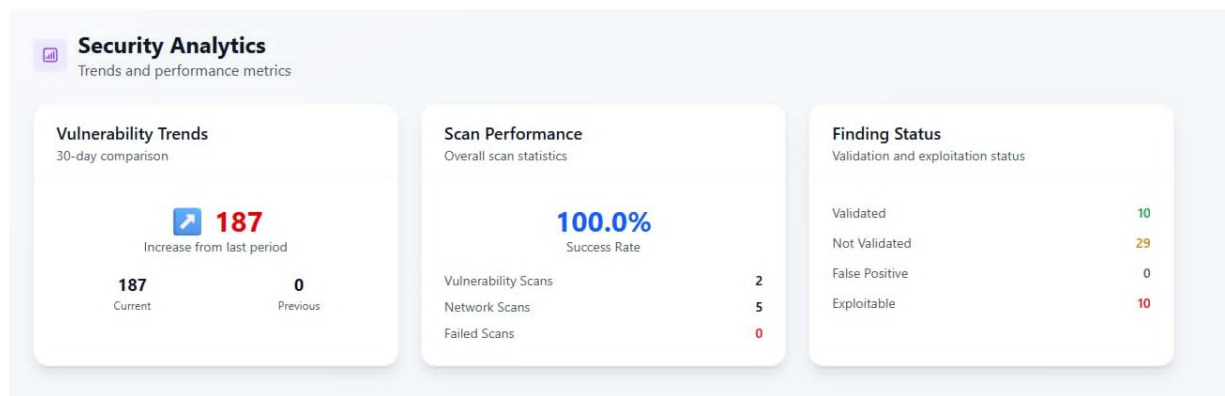


Hình 5-7 Threat Intelligence

Trang tóm tắt thông tin Assets và thống kê số lần scan:



Hình 5-8 Asset Management



Hình 5-9 Security Analytics

Chương 6 Tổng kết

6.1. Kết quả đạt được

Nghiên cứu lý thuyết

- Hệ thống CTEM: Đã nghiên cứu về 5 giai đoạn của một hệ thống CTEM, sự khác biệt giữa CTEM và các giải pháp quản lý lỗ hổng truyền thống, lợi ích và hạn chế khi triển khai hệ thống CTEM
- Tìm hiểu được một số nền tảng CTEM có sẵn, qua đó nắm được các điểm mạnh và các dịch vụ mà nó cung cấp, tạo điều kiện trong việc xây dựng một hệ thống CTEM trong thực tế cho doanh nghiệp.

Kết quả thực hành

- Tìm hiểu được các công cụ mã nguồn mở và các công nghệ để xây dựng 1 hệ thống CTEM hoàn chỉnh
- Xây dựng được một hệ thống CTEM minh họa cho hệ thống gồm 1 máy chủ và 2 máy client với các chức năng tương ứng với 4 giai đoạn: Scoping, Discovery và Prioritization, Validation.

Đánh giá

Đề tài đã hoàn thành tốt cả phần lý thuyết và thực hành, điều này đã góp phần chứng minh tính khả thi và hiệu quả của hệ thống CTEM trong vấn đề quản lý lỗ hổng bảo mật. Về lý thuyết, đề tài đã đưa ra các khái niệm cốt lõi của hệ thống CTEM, hiểu rõ quy trình 5 giai đoạn, phân tích được điểm khác biệt so với các phương pháp quản lý lỗ hổng truyền thống cũng như đánh giá được lợi ích và thách thức khi triển khai. Ở phần thực

hành, việc lựa chọn các công cụ mã nguồn mở để xây dựng một hệ thống CTEM minh họa là hợp lý và có tính thực tiễn cao. Hệ thống được xây dựng có đầy đủ các chức năng theo 4 giai đoạn chính, đáp ứng được mục tiêu ban đầu của đề tài và có thể làm nền tảng cho các nghiên cứu hoặc triển khai thực tế sau này.

6.2. Hướng phát triển

Trong đề tài này, hệ thống CTEM của nhóm chỉ sử dụng các công cụ mã nguồn mở có sẵn và chưa đa dạng về các lĩnh vực. Nhóm dự định sẽ tích hợp thêm những công cụ khác để có cái nhìn đa chiều hơn trong việc quản lý lỗ hổng, đồng thời sẽ xây dựng công cụ quét riêng với các tính năng tốt hơn và phù hợp hơn với mục đích sử dụng.

Trong tương lai, hệ thống sẽ mở rộng với các tính năng mới như hỗ trợ xuất báo cáo chi tiết, quản lý lỗ hổng theo thời gian thực và gửi thông báo cho người dùng. Bên cạnh đó, nhóm sẽ tích hợp mô hình CI/CD pipelines để tự động hóa toàn bộ quá trình, giúp việc hoạt động và cập nhật của hệ thống được tốt hơn.

Ngoài ra, việc sử dụng trí tuệ nhân tạo đang là xu hướng của mọi lĩnh vực và CTEM không phải là một ngoại lệ. Tích hợp trí tuệ nhân tạo trong việc phân tích các báo cáo và cảnh báo sớm nguy cơ tấn công sẽ giúp hệ thống đưa ra các khuyến nghị phòng thủ chính xác hơn, ưu tiên xử lý các lỗ hổng có rủi ro cao, và tự động nhận diện các mẫu tấn công mới.

6.3. Kết luận

Đề tài đã chứng minh tính khả thi của hệ thống CTEM trong việc quản lý các lỗ hổng bảo mật. Nghiên cứu không đưa ra những lợi ích mà hệ thống CTEM mang lại mà còn mở đường cho việc mở rộng hệ thống CTEM cho các doanh nghiệp. Kết quả này là tiền đề quan trọng để phát triển các hệ thống quản lý lỗ hổng bảo mật trong tương lai.

Tài liệu tham khảo

- [1] VNCS. “Giải mã khái niệm CTEM trong ngành An toàn thông tin.”
VNCS, <https://vncs.vn/vi/tin-tuc/detail-giai-ma-khai-niem-ctem-trong-nganh-an-toan-thong-tin-392> . Truy cập ngày 23/7/2025
- [2] CyCognito. “Continuous Threat Exposure Management (CTEM).”
CyCognito, <https://www.cycognito.com/learn/exposure-management/ctem.php> .
Truy cập ngày 23/7/2025
- [3] Rapid7. “What Is Continuous Threat Exposure Management (CTEM)?”
Rapid7, <https://www.rapid7.com/fundamentals/what-is-continuous-threat-exposure-management-ctem/>. Truy cập ngày 23/7/2025
- [4] Reflectiz. “What is CTEM?” Reflectiz,
<https://www.reflectiz.com/blog/what-is-ctem/>. Truy cập ngày 23/7/2025
- [5] Cymulate. “What is Continuous Threat Exposure Management?”
Cymulate, <https://cymulate.com/blog/what-is-continuous-threat-exposure-management/>. Truy cập ngày 23/7/2025
- [6] Gartner. “How to Manage Cybersecurity Threats, Not Episodes.”
Gartner, <https://www.gartner.com/en/articles/how-to-manage-cybersecurity-threats-not-episodes>. Truy cập ngày 23/7/2025
- [7] XM Cyber. “CTEM 101: Continuous Threat Exposure Management.”
XM Cyber, <https://xmcyber.com/ctem-101/>. Truy cập ngày 23/7/2025

- [8] Hookana, Risto. “Continuous Threat Exposure Management and Security Validation.” Theseus.fi,
https://www.theseus.fi/bitstream/handle/10024/851038/Hookana_Risto.pdf?sequence=2&isAllowed=y#page=53&zoom=100,72,573. Truy cập ngày 23/7/2025
- [9] Majid, M. A., Rahman, M. R., et al. “A New Cybersecurity Threat Exposure Management Framework.” International Journal of Current Science Research and Review, Vol. 7, No. 4, April 2024, <https://ijcsrr.org/wp-content/uploads/2024/04/21-1204-2024.pdf>. Truy cập ngày 23/7/2025
- [10] Splunk. “Continuous Threat Exposure Management (CTEM).” Splunk, https://www.splunk.com/en_us/blog/learn/continuous-threat-exposure-management-ctem.html. Truy cập ngày 23/7/2025
- [11] Picus Labs. “What Is Continuous Threat Exposure Management (CTEM)?” Picus Security, 2023, <https://www.picussecurity.com/resource/glossary/what-is-continuous-threat-exposure-management-ctem>. Truy cập ngày 23/7/2025
- [12] CTI Technology. “What Is A Continuous Threat Exposure Management System?” CTI Technology, <https://ctinc.com/what-is-a-continuous-threat-exposure-management-system/>. Truy cập ngày 23/7/2025
- [13] Nanitor. “Nanitor Cyber Hygiene Platform.” Nanitor, <https://nanitor.com/>. Truy cập ngày 23/7/2025

- [14] Nanitor. “Diamond Vision – Continuous Visibility of Cyber Hygiene.” Nanitor, <https://nanitor.com/diamond-vision/>. Truy cập ngày 23/7/2025
- [15] Tenable. “Cyber Exposure Solutions.” Tenable, <https://www.tenable.com/>. Truy cập ngày 23/7/2025
- [16] Tenable. “Cybersecurity Solutions.” Tenable, <https://www.tenable.com/solutions>. Truy cập ngày 23/7/2025
- [17] Tenable. “Nessus Vulnerability Scanner.” Tenable, <https://www.tenable.com/products/nessus>. Truy cập ngày 23/7/2025
- [18] Pacisoft. “Tenable Nessus là gì? So sánh Nessus Professional với Nessus Expert” Pacisoft , <https://www.pacisoft.vn/tin-san-pham/tenable-nessus-la-gi-so-sanh-nessus-professional-voi-nessus-expert> Truy cập ngày 23/7/2025
- [19] XM Cyber. “XM Cyber – Continuous Exposure Management.” XM Cyber, <https://xmcyber.com/>. Truy cập ngày 23/7/2025
- [20] XM Cyber. “Choke Points: The New Approach to Ultra-Efficient Remediation.” XM Cyber, <https://info.xmcyber.com/choke-points-the-new-approach-to-ultra-efficient-remediation>. Truy cập ngày 23/7/2025
- [21] XM Cyber. “Use Cases.” XM Cyber, <https://xmcyber.com/use-case/>. Truy cập ngày 23/7/2025

Phụ lục A

A

AI – SPM (AI Security Posture Management): Quản lý tư thế bảo mật với trí tuệ nhân tạo

API (application programming interface): Giao diện lập trình ứng dụng

C

CI (Continuous Integration): Tích hợp liên tục

CD (Continuous Delivery): Phân phối liên tục

CNAPP (Cloud-Native Application Protection Platform): Nền tảng bảo vệ ứng dụng gốc trên đám mây

CNTT: Công nghệ thông tin

CTEM (Continuous Threat Exposure Management)

CVSS (Common Vulnerability Scoring System)

CVE (Common Vulnerabilities and Exposures)

D

DAST (Dynamic Application Security Testing): Kiểm tra bảo mật ứng dụng động

E

EASM (External Attack Surface Management): Quản lý bề mặt tấn công bên ngoài

ESTI (European Telecommunications Standards Institute): Viện Tiêu chuẩn Viễn thông châu Âu

G

GCP (Google Cloud Platform): Dịch vụ điện toán đám mây do Google cung cấp

H

HTTP (Hypertext Transfer Protocol): Giao thức tiêu chuẩn để truyền tải dữ liệu trên World Wide Web

HTTPS (Hypertext Transfer Protocol Secure): Giao thức truyền tải siêu văn bản an toàn và bảo mật, là một phiên bản nâng cấp an toàn của giao thức HTTP

I

IaC (Infrastructure as Code): Cơ sở hạ tầng dưới dạng mã

IAM (Identity and Access Management): Quản lý Danh tính và Truy cập

ITDR (Identity threat detection and response): Phát hiện và Ứng phó Mọi đe dọa Danh tính

IP (Internet Protocol): Địa chỉ IP

R

RBVM (Risk-based Vulnerability Management): Quản lý Lỗ hổng Dựa trên Rủi ro

S

SaaS (Software as a Service): Phần mềm dạng dịch vụ

SOAR (Security Orchestration, Automation and Response): Điều phối, tự động hóa và phản hồi bảo mật

Phụ lục B

1. Thiết lập các thủ tục cần thiết

1.1. Cập nhật hệ thống

```
sudo apt update  
  
sudo apt upgrade -y
```

1.2. Cài đặt Nmap

```
sudo apt install nmap -y
```

1.3. Cài đặt PostgreSQL

```
sudo apt install postgresql postgresql-contrib -y
```

1.4. Cài đặt Greenbone OpenVAS

Cài đặt gvm và thiết lập dữ liệu và tài nguyên

```
sudo apt install -y gvm  
  
sudo gvm-setup
```

Kiểm tra và khởi động gvm

```
sudo gvm-check-setup  
  
sudo gvm-start
```

Tạo chứng chỉ TLS (nếu chưa có)

```
sudo gvm-manage-certs -a
```

Tạo tài khoản “admin” và đặt mật khẩu “123456”

```
sudo gvmc --create-user=admin
```

```
sudo gvmc --user=admin --new-password="123456"
```

2. Thiết lập hệ thống

2.1. Sao chép kho lưu trữ

```
git clone https://github.com/your-org/ctem-webapp.git
```

```
cd ctem-webapp
```

2.2. Thiết lập back-end

```
cd backend
```

```
npm install
```

```
# Create .env file
```

```
echo
"DATABASE_URL=postgresql://postgres:postgres@localhost:5432/ctem_webapp_
dev

PORT=3001

NODE_ENV=development

FRONTEND_URL=http://localhost:5173" > .env

# Start the PostgreSQL database

npm run db:start

# Initialize the database schema

npm run db:update
```

2.3. Thiết lập front-end

```
cd ../frontend

npm install
```

2.4. Khởi động hệ thống

Back-end

```
cd backend  
  
npm run dev
```

Front-end

```
cd frontend  
  
npm run dev
```